



NTLM

Ing. Ondřej Ševeček | GOPAS a.s. |

MCSM:Directory2012 | MCM:Directory2008 | MVP:Enterprise Security |
Certified Ethical Hacker | CISA |

ondrej@sevecek.com | www.sevecek.com |

GOPAS: info@gopas.cz | www.gopas.cz | www.facebook.com/P.S.GOPAS

NTLM family

- LM
 - OS/2
- NTLM
 - Windows NT 3.51
- NTLMv2
 - Windows NT 4.0 SP4
 - default since 2008/Vista

The NTLM family cons

- Weak cryptography
 - LM, MD4, DES, HMAC-MD5
- No mutual authentication (= MITM)
 - requires NTLMv2 session security or other channel authentication (TLS, IPSec)
- Bad reply protection except for NTLMv2
- Reflection attacks
- Bad performance especially over trusts
- Session security still prone to offline password attacks (no PFS)
 - yields full transmission data

The NTLM family pros

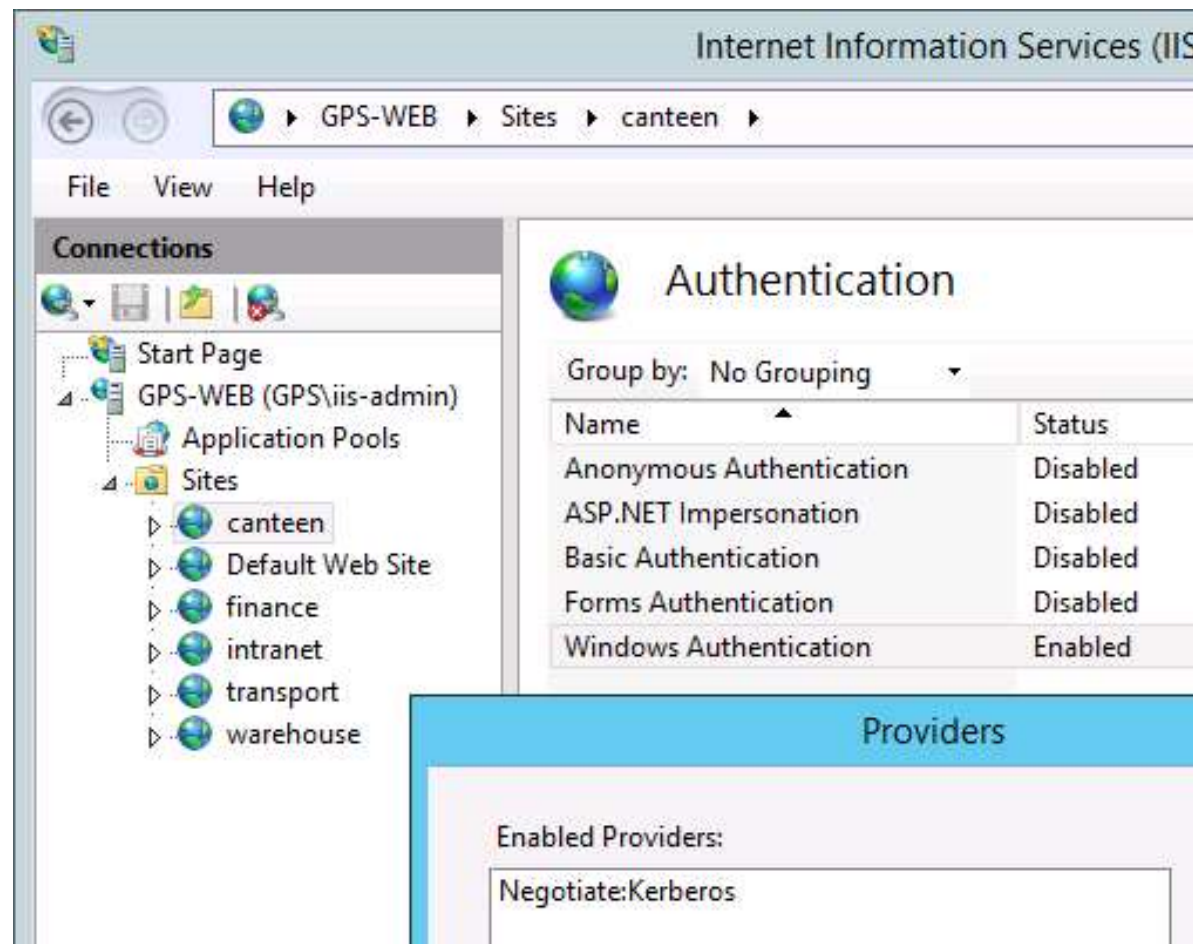
- Works from the internet
 - MITM prevented with TLS/HTTPS/RDPS
- SSO as against basic authentication
- Easy, minimum requirements, smooth fallback

When NTLM gets used

- Any **non-domain** account or computer
- DCs not available (internet)
 - Kerberos over KDC Proxy
- External domain trusts
 - non-transitive
 - do not require DFL 2003
- **IP address** or DNS **A alias** used by client
 - CNAME translates usually to the target name
 - PTR records are not used
- IE not in **local intranet** or **trusted sites** (IE 7+)
 - Chrome, Edge, Edge Chromium, WebDAV, ...
- IE without **Enable Windows Integrated Authentication** setting
- **MS-CHAP** = NTLM, **MS-CHAPv2** = NTLMv2

Services which require Kerberos

- AD replication
- System Center agents
- DNS dynamic update
- SYSTEM account on Windows Vista/2008-
- PS-Remoting
 - Enter-PSSession
- SYSVOL and NETLOGON hardening by default 10/2026+



PS remoting (Enter-PSSession) with NTLM

comma (,) separated list

```
Set-Item WSMan:\localhost\Client\TrustedHosts
```

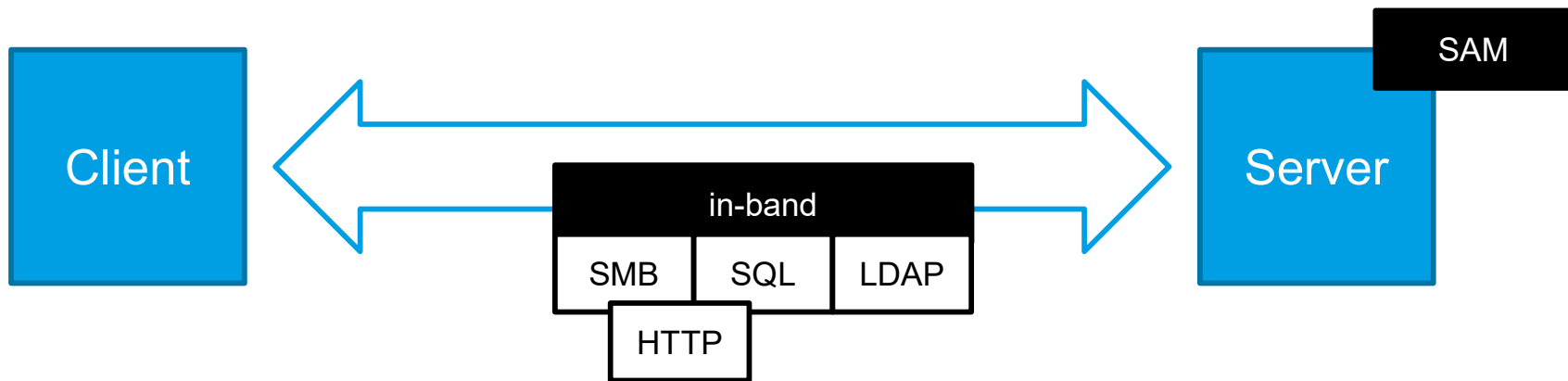
must supply **explicit** credentials

```
Enter-PSSession -Credential
```

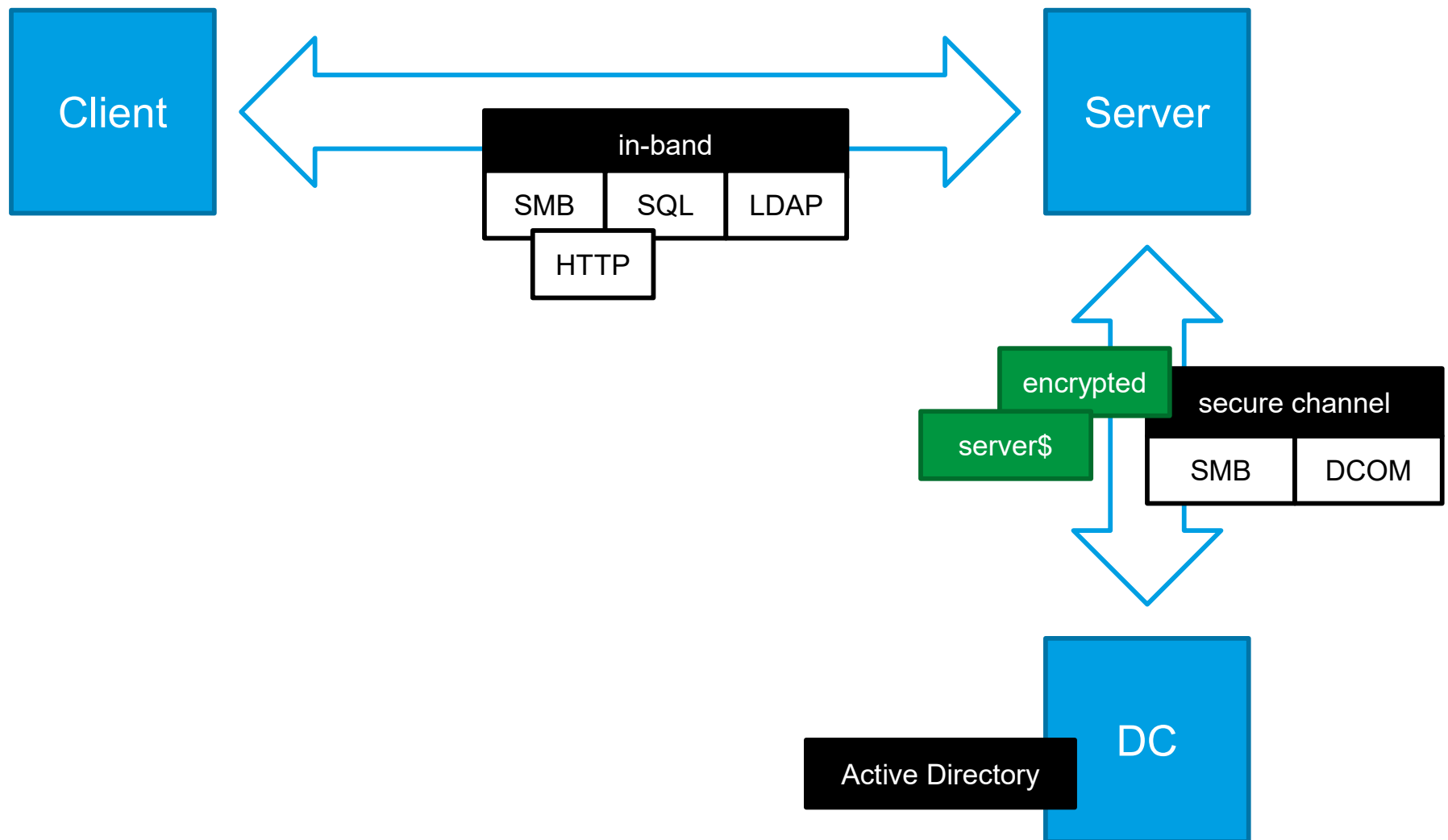
 Administrator: Windows PowerShell

```
PS C:\>  
PS C:\> Set-Item WSMan:\localhost\Client\TrustedHosts '10.10.0.16, 10.10.0.17' -Force  
PS C:\> Enter-PSSession 10.10.0.16 -Credential (Get-Credential)
```

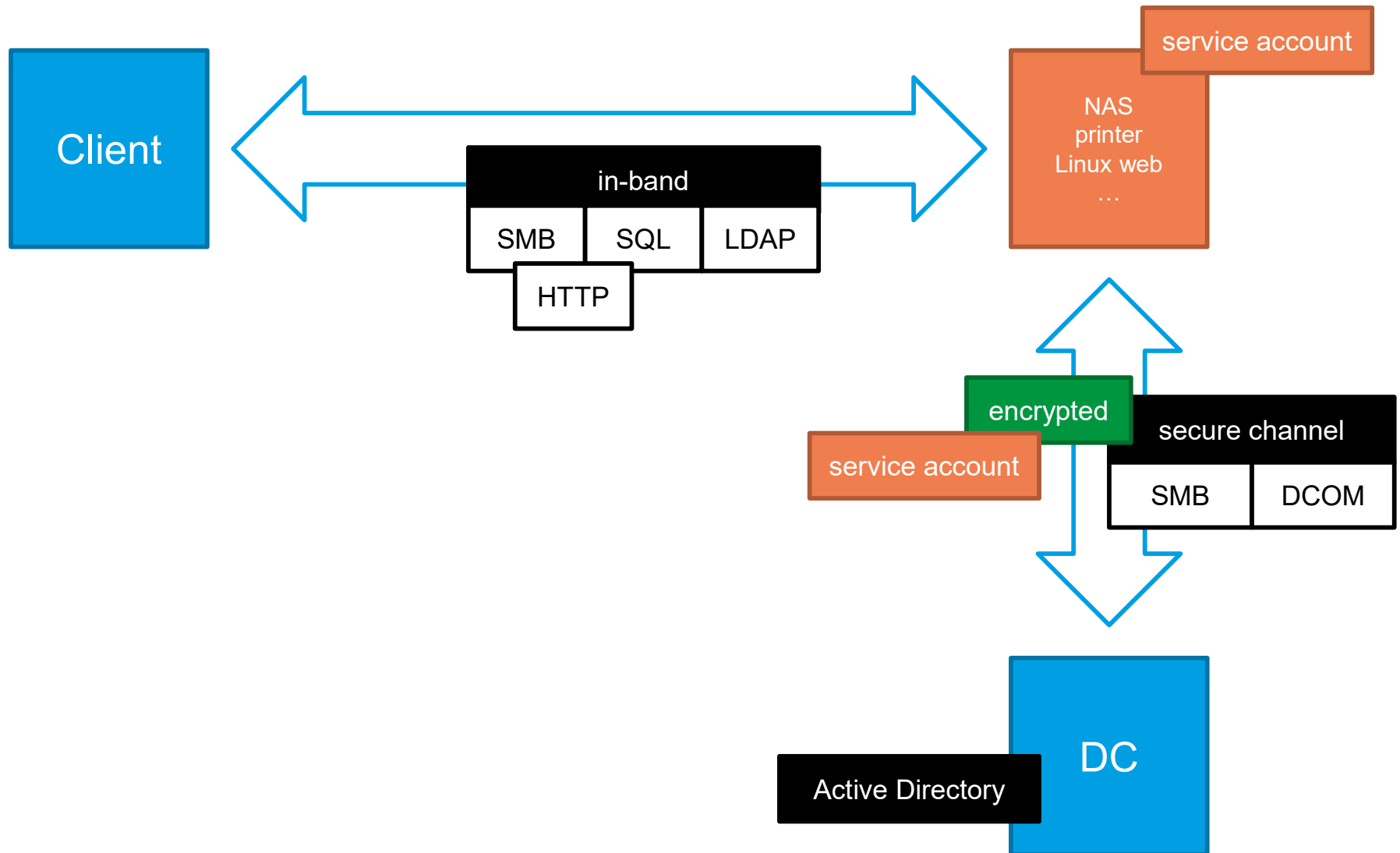
In-band NTLM with local accounts



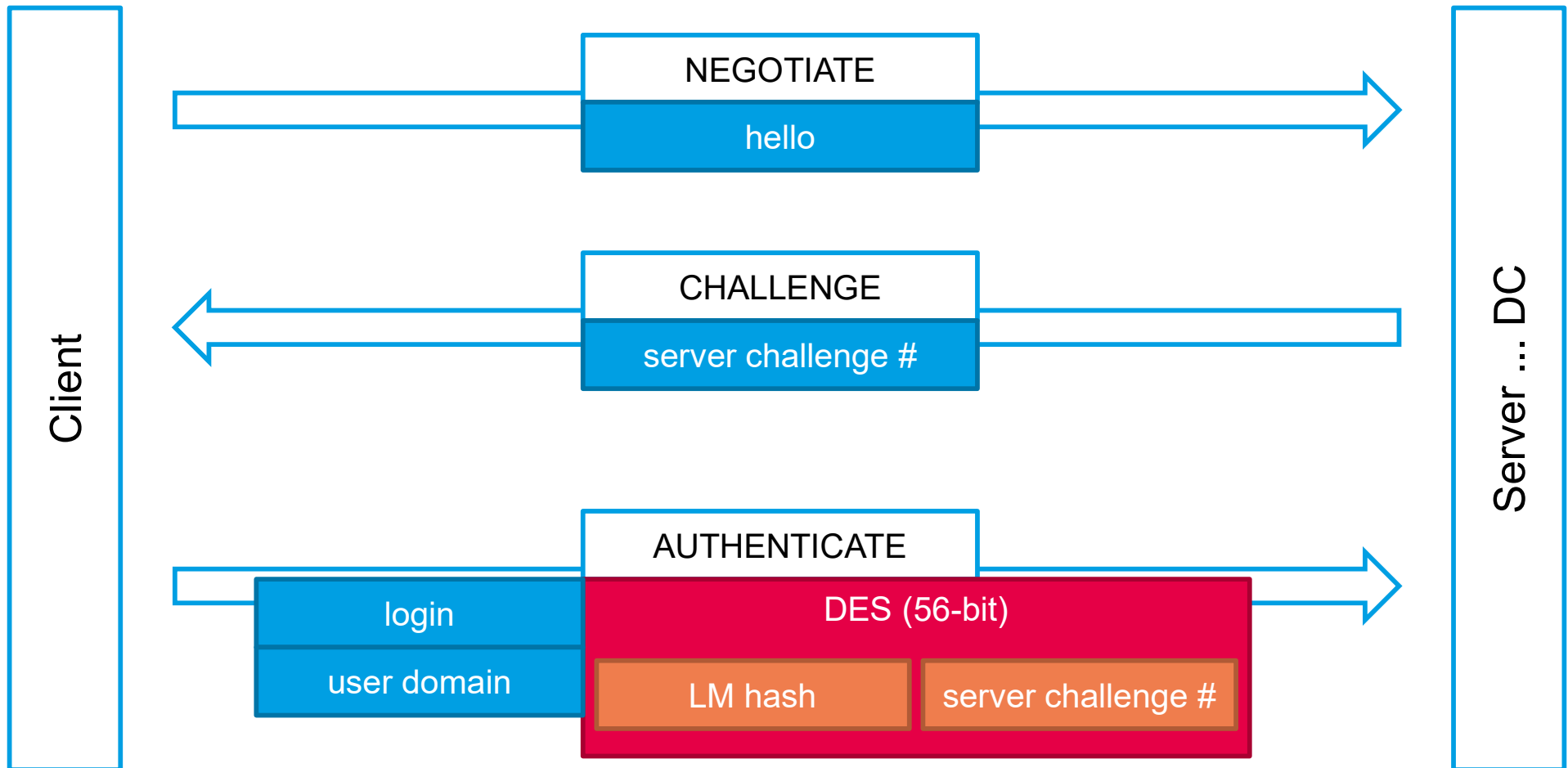
Pass-through NTLM with domain accounts



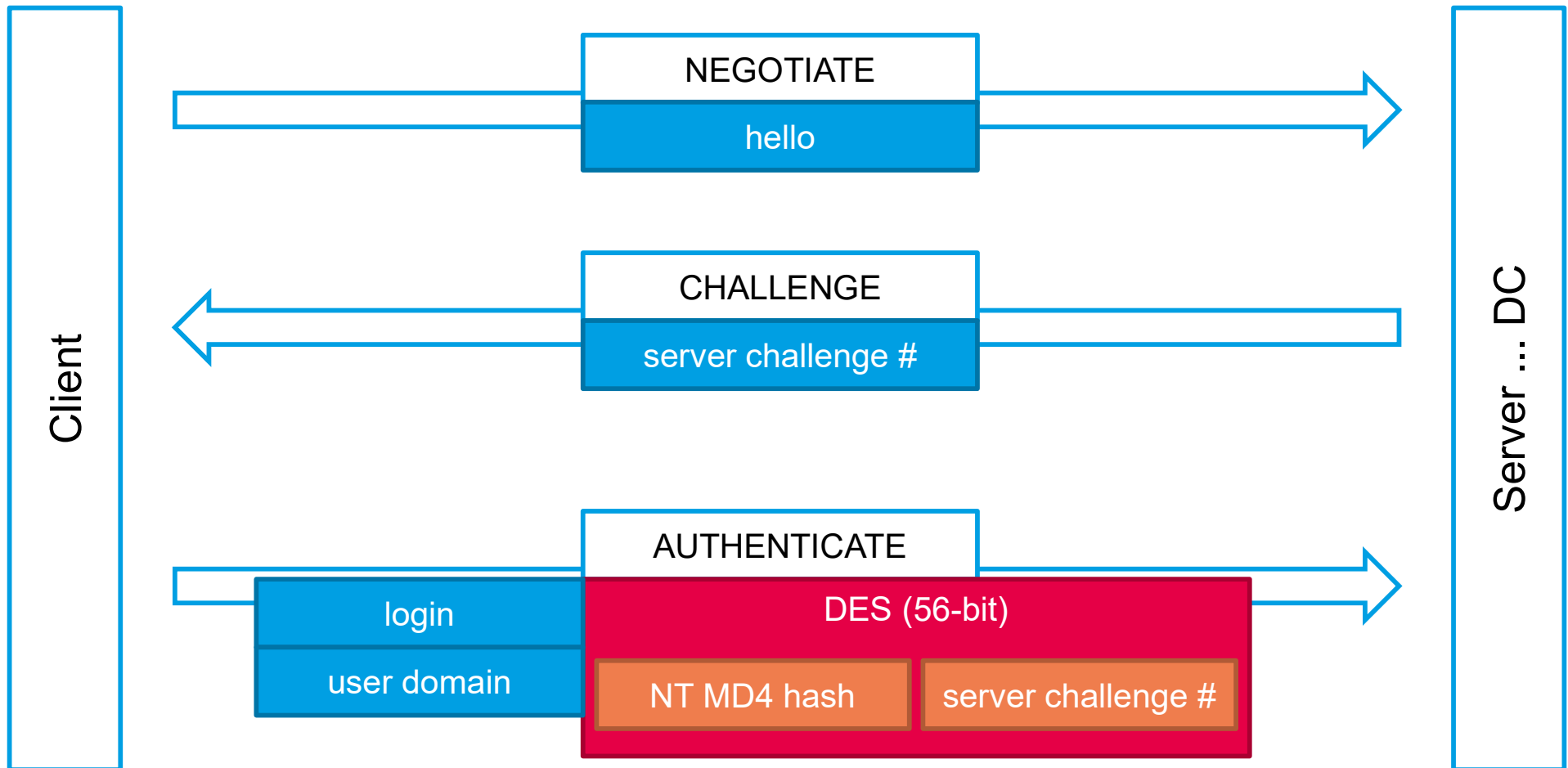
Pass-through NTLM with domain accounts with non-Windows servers



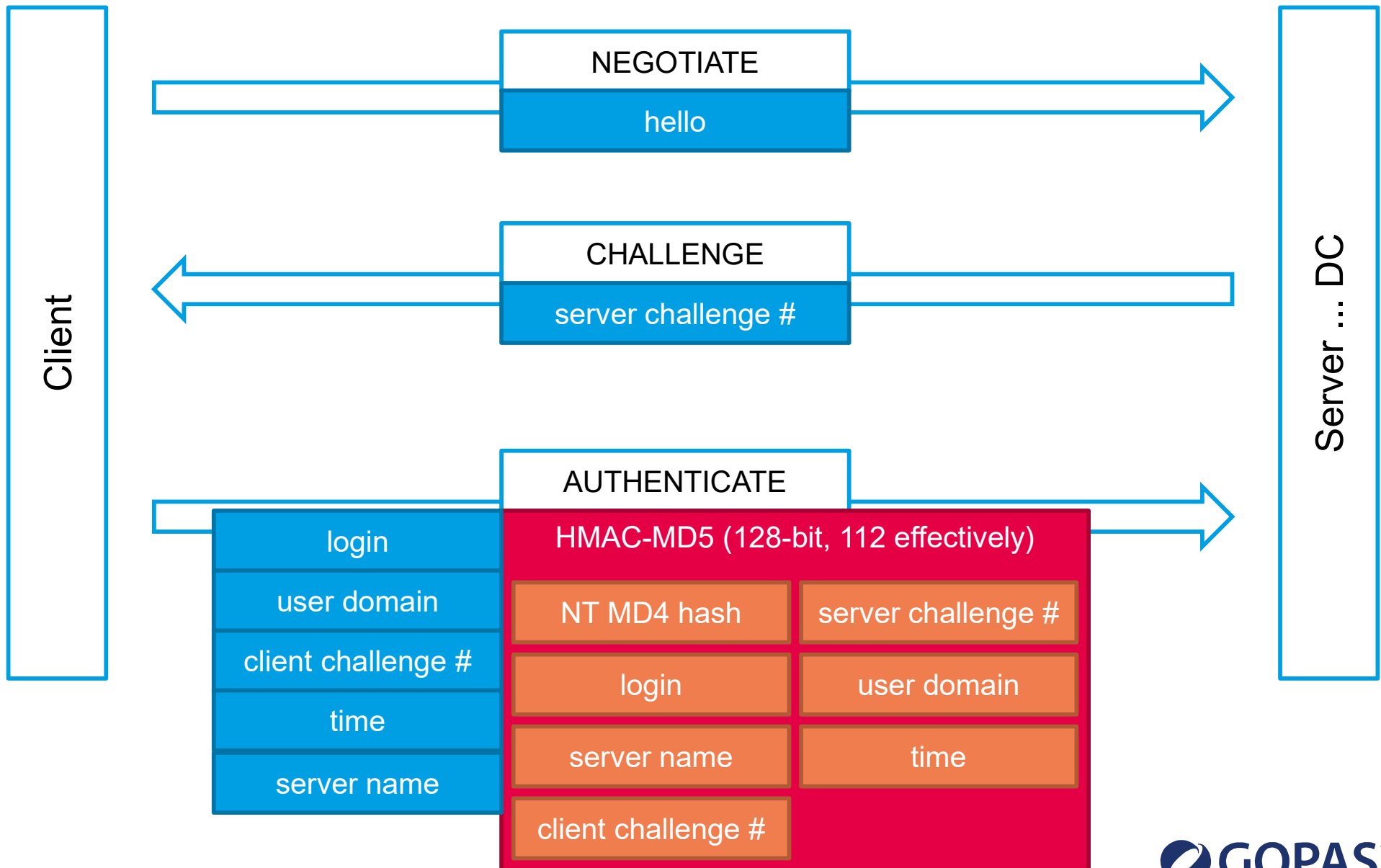
LM authentication (ultra weak)



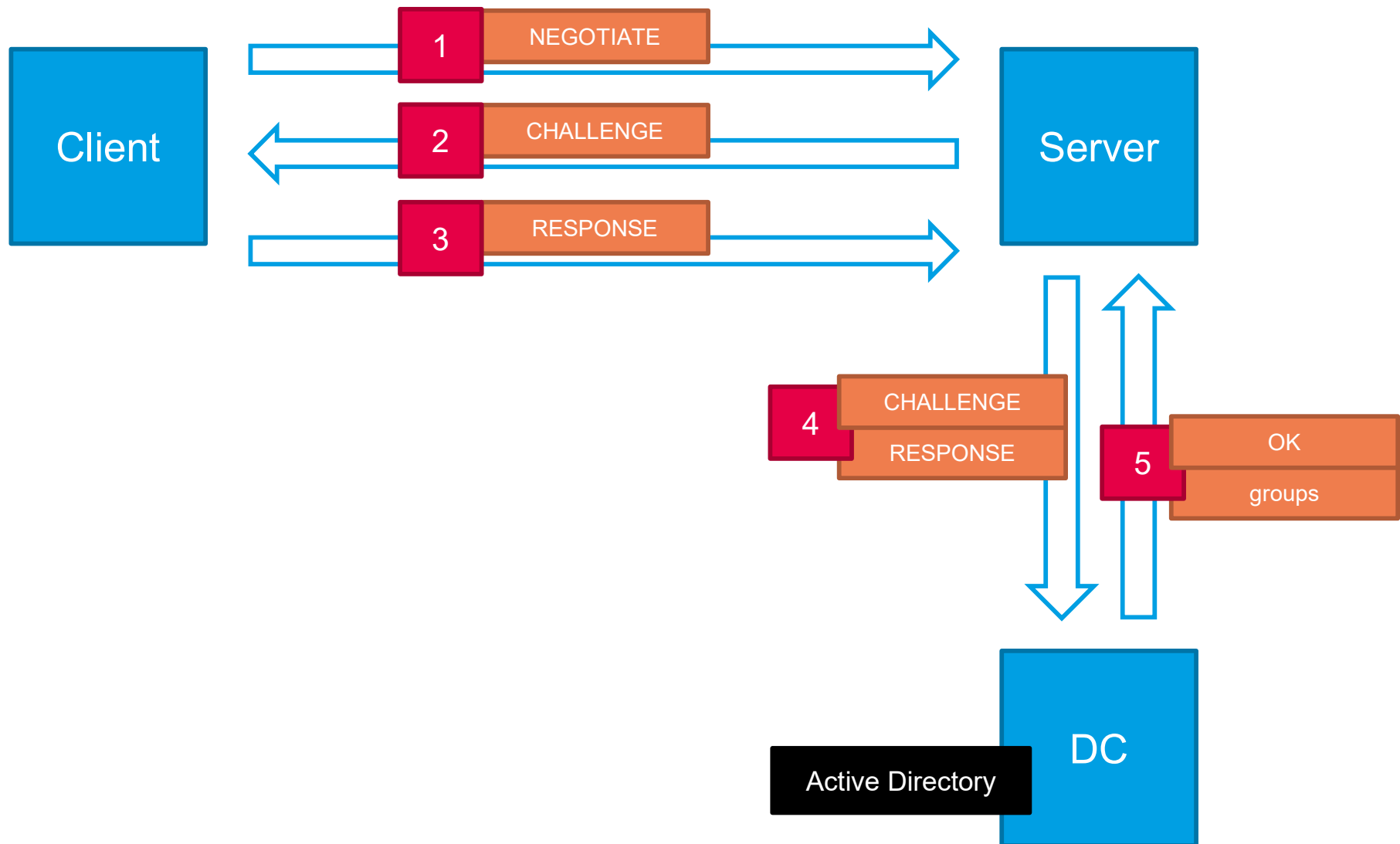
NTLM authentication (weak)



NTLMv2 authentication (best, yet not ideal)



NTLM with domain accounts



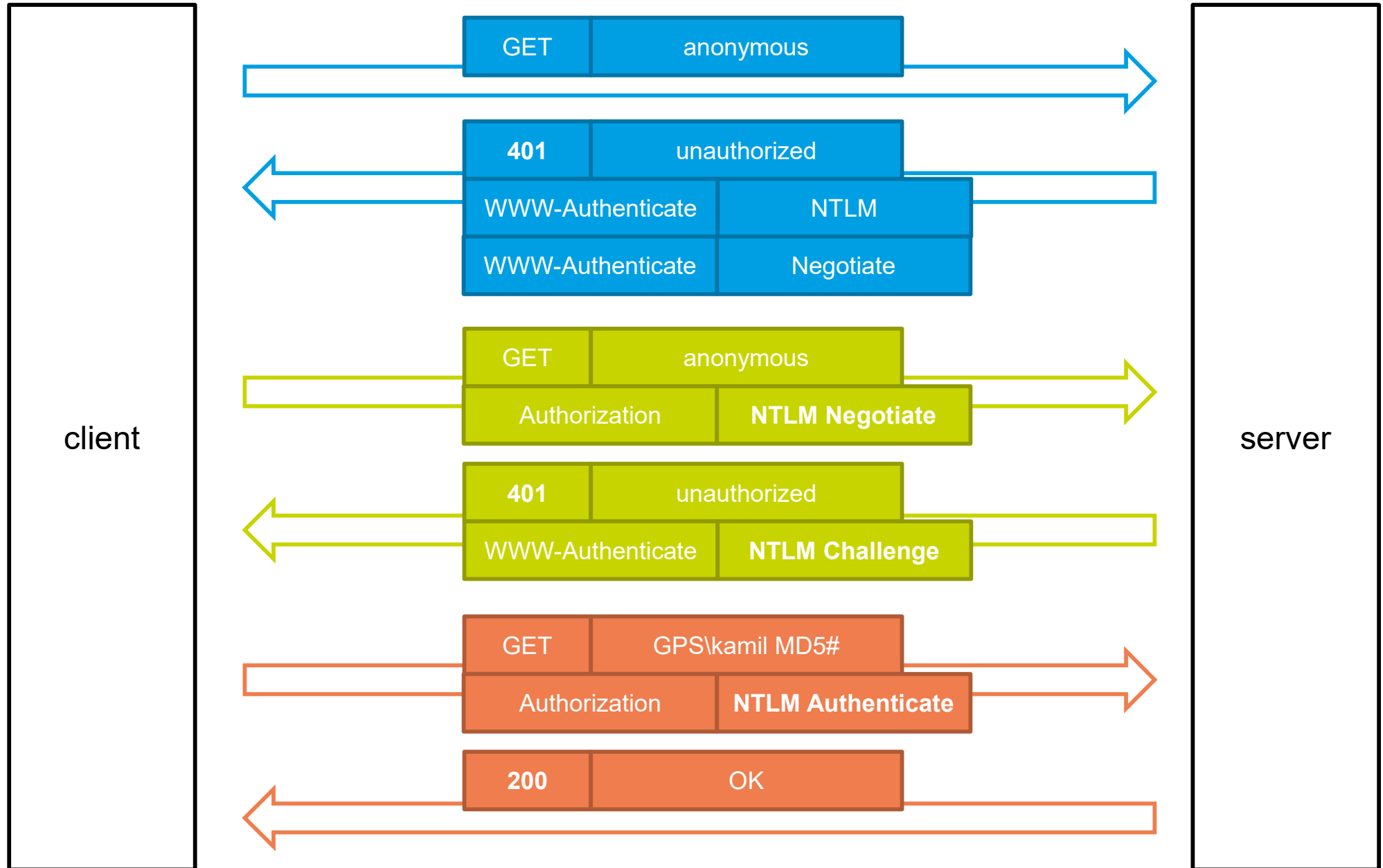
Testing authentication with default credentials

```
Invoke-WebRequest http://intranet -UseDefaultCredentials
```

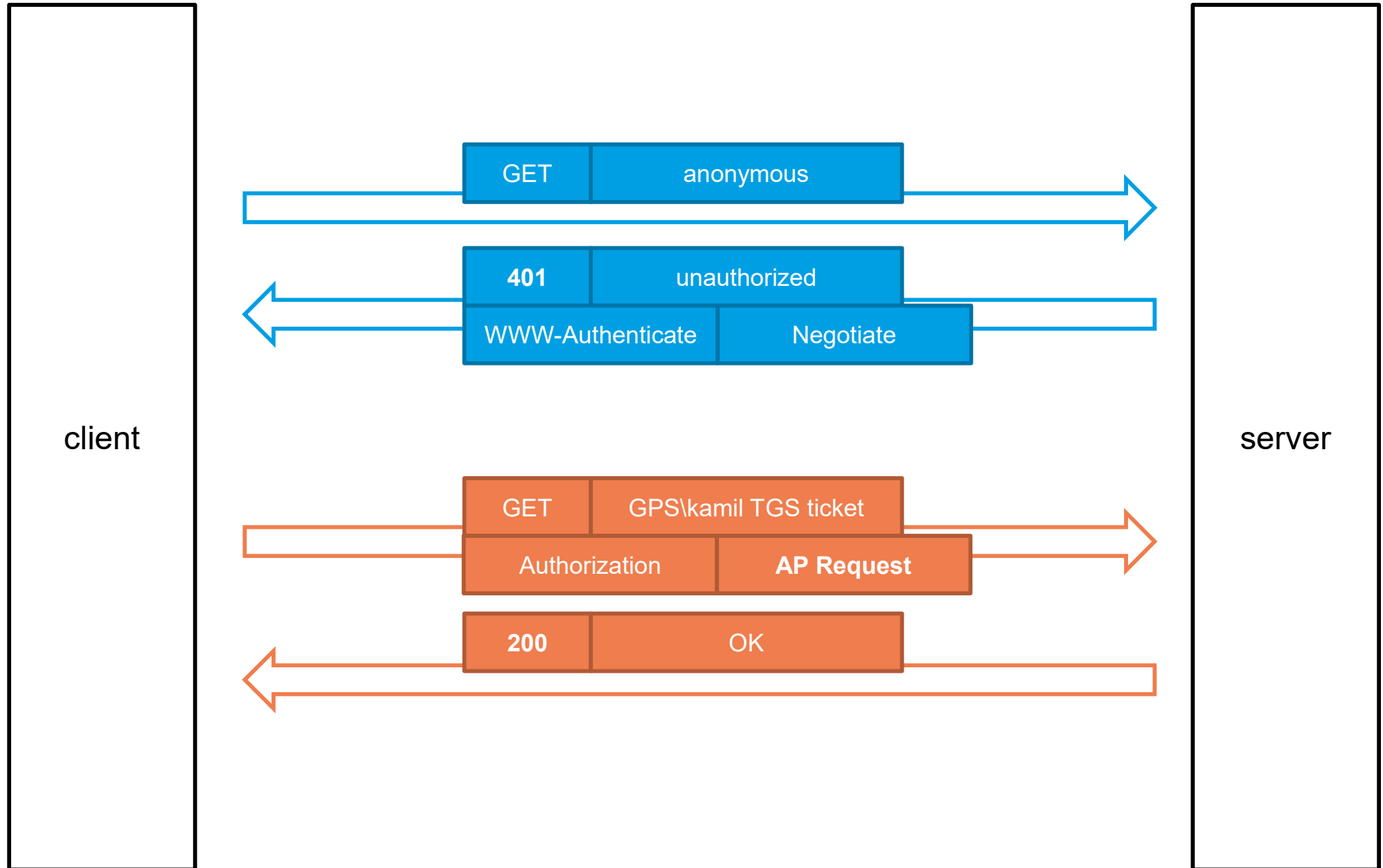
```
# Note: Pooling=False means that the connection is going to be
#       reestablished every time you use even the same connection
#       string. For our purposes no need then to use the cleanup:
#       $conn.Close()
#       $conn.Dispose()
#       $conn = $null
#       [GC]::Collect()
#       [GC]::WaitForPendingFinalizers()
$conn = New-Object Data.SqlClient.SqlConnection
'Pooling=False;Server=data\INFOSYS;Database=master;Integrated
Security=true'
$conn.Open()

# Note: shared files are going to keep the connection established
#       for at least 20seconds or even more, so be slow
net view \\data /all
```

LM/NTLM/NTLMv2 in HTTP



Kerberos in HTTP



LM/NTLM/NTLMv2 negotiate message (Client to Server)

```
[-] MechToken: NTLM NEGOTIATE MESSAGE
  [-] NLMP: NTLM NEGOTIATE MESSAGE
    ..... Signature: NTLMSSP
    ..... MessageType: Negotiate Message (0x00000001)
    [+] NegotiateFlags: 0xE2088297 (NTLM v2128-bit encryption, Always Sign)
    [+] DomainNameFields: Length: 0, Offset: 0
    [+] WorkstationFields: Length: 0, Offset: 0
    [+] Version: Windows 6.2 Build 9200 NLMPv15
```

LM/NTLM/NTLMv2 challenge message (Server to Client)

```
[-] ResponseToken: NTLM CHALLENGE MESSAGE
  [-] NLMP: NTLM CHALLENGE MESSAGE
    ...Signature: NTLMSSP
    ...MessageType: Challenge Message (0x00000002)
    [+ TargetNameFields: Length: 6, Offset: 56
    [+ NegotiateFlags: 0xE2898215 (NTLM v2128-bit encryption, Always Sign)
    [+ ServerChallenge: 8FF4777E24F10017
    ...Reserved: Binary Large Object (8 Bytes)
    [+ TargetInfoFields: Length: 138, Offset: 62
    [+ Version: Windows 6.2 Build 9200 NLMPv15
    ...TargetNameString: GPS
    [-] AvPairs: 7 pairs
      [+ AvPair: GPS (Server NetBIOS domain name)
      [+ AvPair: SRV1 (Server NetBIOS computer name)
      [+ AvPair: GOPAS.virtual (The FQDN (2) of the domain.)
      [+ AvPair: SRV1.GOPAS.virtual (The fully qualified domain name (FQDN (1)) of the computer.)
      [+ AvPair: GOPAS.virtual (The FQDN (2) of the forest.)
      [+ AvPair: 12:42:15 17. 12. 2013 (Server local time)
      [+ AvPair: NULL
```

LM and NTLMv1 response (Client to Server)

```
[-] ResponseToken: NTLM AUTHENTICATE MESSAGEVersion:v1, Domain: GPS, User: wks-admin, Workstation: WKS
  [-] NLMP: NTLM AUTHENTICATE MESSAGEVersion:v1, Domain: GPS, User: wks-admin, Workstation: WKS
    ...Signature: NTLMSSP
    ...MessageType: Authenticate Message (0x00000003)
    [+ LmChallengeResponseFields: Length: 24, Offset: 118
    [+ NtChallengeResponseFields: Length: 24, Offset: 142
    [+ DomainNameFields: Length: 6, Offset: 88
    [+ UserNameFields: Length: 18, Offset: 94
    [+ WorkstationFields: Length: 6, Offset: 112
    [+ EncryptedRandomSessionKeyFields: Length: 16, Offset: 166
    [+ NegotiateFlags: 0xE2888215 (NTLM v2128-bit encryption, Always Sign)
    [+ Version: Windows 6.2 Build 9200 NLMPv15
    [+ MessageIntegrityCheckNotPresent: A79EEF5C836AA0C9CA32AA2EF0D38143
    ...DomainNameString: GPS
    ...UserNameString: wks-admin
    ...WorkstationString: WKS
    [-] LmChallengeResponseStruct: 9A45186FA34097DA000000000000000000000000000000000000
      [+ Response: 9A45186FA34097DA00000000000000000
      [+ ChallengeFromClient: 0000000000000000
    [+ NTLMV1ChallengeResponse: 80350344A15F28FE0AF411ADF92516C0EB8F3CE824E5EC7A
    [+ SessionKeyString: 9D6445F8E797646EDFFF1F0F32963B08
```


NTLMv2 response (Client to Server)

```
[-] ResponseToken: NTLM AUTHENTICATE MESSAGEVersion:v2, Domain: GPS, User: wks-admin, Workstation: WKS
  [-] NLMP: NTLM AUTHENTICATE MESSAGEVersion:v2, Domain: GPS, User: wks-admin, Workstation: WKS
    ...Signature: NTLMSSP
    ...MessageType: Authenticate Message (0x00000003)
    [+ LmChallengeResponseFields: Length: 24, Offset: 118
    [+ NtChallengeResponseFields: Length: 304, Offset: 142
    [+ DomainNameFields: Length: 6, Offset: 88
    [+ UserNameFields: Length: 18, Offset: 94
    [+ WorkstationFields: Length: 6, Offset: 112
    [+ EncryptedRandomSessionKeyFields: Length: 16, Offset: 446
    [+ NegotiateFlags: 0xE2888215 (NTLM v2128-bit encryption, Always Sign)
    [+ Version: Windows 6.2 Build 9200 NLMPv15
    [+ MessageIntegrityCheck: CCB4D486FE621480DA4ECE7C55AF36EFA
      ...DomainNameString: GPS
      ...UserNameString: wks-admin
      ...WorkstationString: WKS
    [-] LmChallengeResponseStruct: 0000000000000000000000000000000000000000000000000000000000000000
      [+ Response: 0000000000000000000000000000000000000000000000000000000000000000
      [+ ChallengeFromClient: 0000000000000000000000000000000000000000000000000000000000000000
    [+ NTLMV2ChallengeResponse: 5DE05B9745F7D15433B0798C50DD8ECA
    [+ SessionKeyString: E6C779A6C1A712D6AC014E262C4AE469
```

Values hashed together in an NTLMv2 response

```
- NTLMV2ChallengeResponse: 4E422594697257C5551763FEC40A9158
  + Response: 4E422594697257C5551763FEC40A9158
    ... ResponseVersion: 1 (0x1)
    ... HiResponseVersion: 1 (0x1)
  + Z1:
    ... Time: 02/28/2023, 11:48:10.970128 UTC
  + ClientChallenge: F631F6D23F8806BE
  + Z2:
    - AvPairs: 11 pairs
      + AvPair: GPS (Server NetBIOS domain name)
      + AvPair: GPS-WEB (Server NetBIOS computer name)
      + AvPair: gopas.virtual (The FQDN (2) of the domain.)
      + AvPair: GPS-WEB.gopas.virtual (The fully qualified domain name)
      + AvPair: gopas.virtual (The FQDN (2) of the forest.)
      + AvPair: 11:48:10 28.02.2023 (Server local time)
      + AvPair: 0x2 (Server configuration)
      + AvPair: 0x3000 (Token restrictions)
      + AvPair: 0x3000 (A channel bindings hash)
      + AvPair: HTTP/intranet.gopas.virtual (The SPN of the target)
      + AvPair: NULL
    ... Padding: Binary Large Object (4 Bytes)
  + SessionKeyString: 9877560CBFA570F7D3ACF4ED181452E3
```

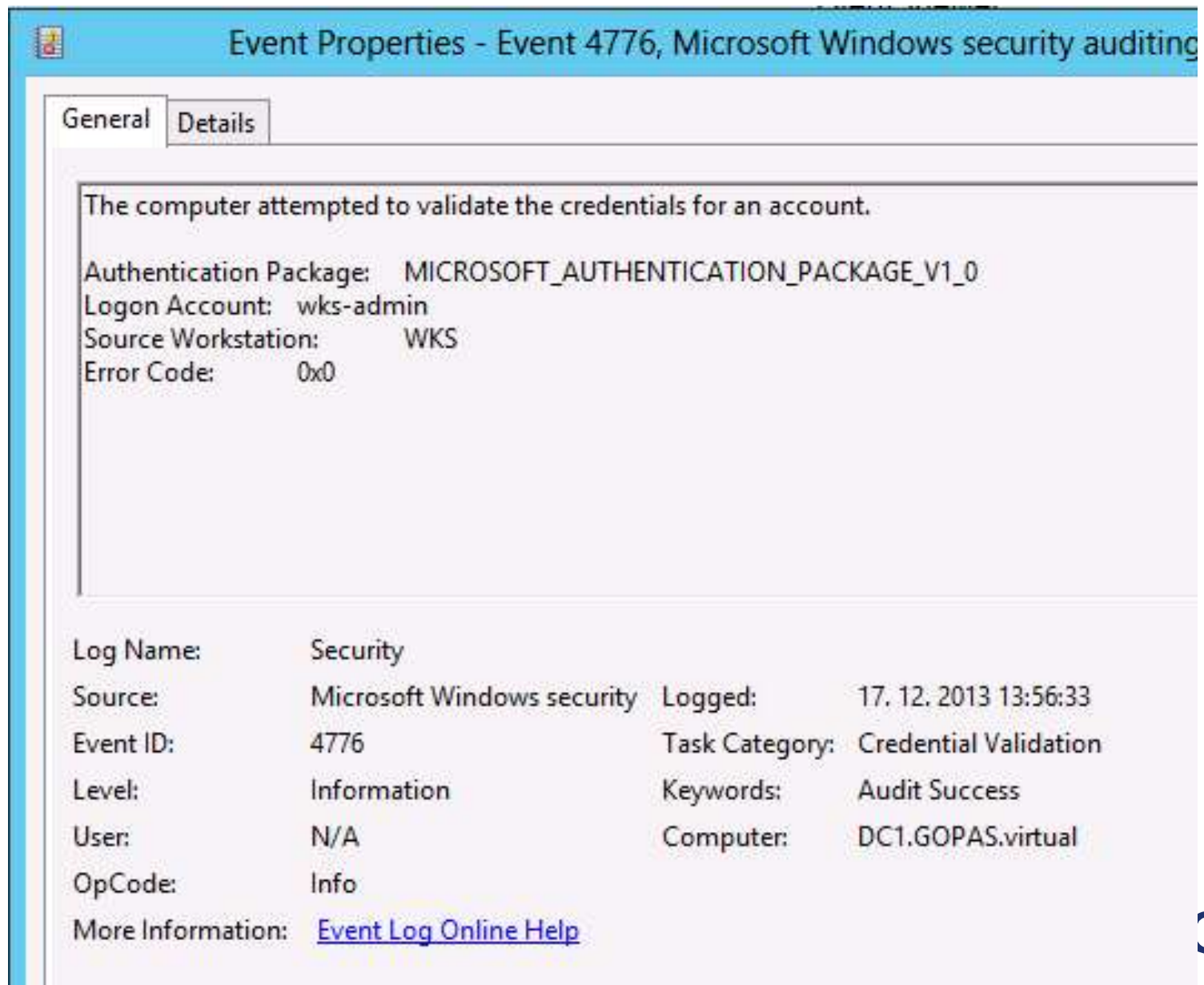
note points:
timestamp
channel binding

Fiddler LM+NTLM vs. NTLMv2 (just bigger)

```
Domain: GPS
User: kamil
Host: GPS-CLIENT10
lm_resp: 5C B7 25 D6 17 9F DF 29 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
nt_resp: 29 81 2F CA 38 9D C7 6D C1 5D 74 0B D1 92 6F 93 17 D1 BC 86 76 B0 BB 79
```

```
Domain: GPS
User: kamil
Host: GPS-CLIENT10
lm_resp: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
nt_resp: C5 56 5F 0F DB 86 E5 50 D1 16 57 E9 D4 6D 1F 53 01 01 00 00 00 00 00 00 82 61 9E
C7 5C 98 D9 01 8C 11 03 3A D7 70 34 DB 00 00 00 00 02 00 06 00 47 00 50 00 53 00 01 00 0E
00 47 00 50 00 53 00 2D 00 57 00 45 00 42 00 04 00 1A 00 67 00 6F 00 70 00 61 00 73 00 2E
00 76 00 69 00 72 00 74 00 75 00 61 00 6C 00 03 00 2A 00 47 00 50 00 53 00 2D 00 57 00 45
00 42 00 2E 00 67 00 6F 00 70 00 61 00 73 00 2E 00 76 00 69 00 72 00 74 00 75 00 61 00 6C
00 05 00 1A 00 67 00 6F 00 70 00 61 00 73 00 2E 00 76 00 69 00 72 00 74 00 75 00 61 00 6C
00 07 00 08 00 82 61 9E C7 5C 98 D9 01 06 00 04 00 02 00 00 00 08 00 30 00 30 00 00 00 00
00 00 00 00 00 00 00 00 30 00 00 DC ED 84 65 DB 86 C9 31 08 65 28 63 50 E1 21 4C 02 FF B3
2B 1F 83 BF C6 6B DA 53 49 FB C3 4B 57 0A 00 10 00 00 00 00 00 00 00 00 00 00 00 00 00
00 00 00 09 00 36 00 48 00 54 00 54 00 50 00 2F 00 69 00 6E 00 74 00 72 00 61 00 6E 00 65
00 74 00 2E 00 67 00 6F 00 70 00 61 00 73 00 2E 00 76 00 69 00 72 00 74 00 75 00 61 00 6C
00 00 00 00 00 00 00 00
```


NTLM success audit on DC



NTLM failure audit on DC

 Event Properties - Event 4776, Microsoft Windows security auditing.

General Details

The computer attempted to validate the credentials for an account.

Authentication Package: MICROSOFT_AUTHENTICATION_PACKAGE_V1_0
Logon Account: kamil
Source Workstation: GPS-CLIENT10
Error Code: 0xC000006A

Log Name:	Security		
Source:	Microsoft Windows security	Logged:	16.04.2019 10:59:06
Event ID:	4776	Task Category:	Credential Validation
Level:	Information	Keywords:	Audit Failure
User:	N/A	Computer:	GPS-DC1.gopas.virtual

NTLM success audit on resource server

The image displays two overlapping screenshots of the Windows Event Viewer, specifically the 'Event Properties' window for Event 4624, which is a 'Successful Logon' event. The top screenshot shows the 'General' tab, and the bottom screenshot shows the 'Details' tab.

General Tab (Top Screenshot):

- Process Information:**
 - Process ID: 0x0
 - Process Name: -
- Network Information:**
 - Workstation Name: WKS
 - Source Network Address: 10.10.0.101
 - Source Port: 49270
- Detailed Authentication Information:**
 - Logon Process: NtLmSsp
 - Authentication Package: NTLM
 - Transited Services: -
 - Package Name (NTLM only): NTLM V2
 - Key Length: 128

Details Tab (Bottom Screenshot):

- Subject:**
 - Security ID: NULL SID
 - Account Name: -
 - Account Domain: -
 - Logon ID: 0x0
- Logon Type:** 3
- Impersonation Level:** Impersonation
- New Logon:**
 - Security ID: GPS\wks-admin
 - Account Name: wks-admin
 - Account Domain: GPS
 - Logon ID: 0x8F21CC
 - Logon GUID: {00000000-0000-0000-0000-000000000000}

Event Description: An account was successfully logged on.

Event Message: This event is generated when a logon session is created. It is generated on the computer that was accessed.

Restricting client computers (userWorkstations attribute)

Kamil R. Properties

Published Certificates	Member Of	Password Replication	Dial-in
Security	Environment	Sessions	Remote control
General	Address	Account	Profile
Remote Desktop Services Profile		COM+	Organization

Attributes:

Attribute	Value
pwdLastSet	
replPropertyMetaD	
sAMAccountName	
sAMAccountType	
sn	
telephoneNumber	
title	junior
userAccountControl	0x200 = (NORMAL_ACCOUNT)
userPrincipalName	rychnovsky.kamil@gopas.cz
userWorkstations	gps-sprdp,gps-client 10
uSNCreated	20542
uSNChanged	77841

String Attribute Editor

Attribute: **userWorkstations**

Value:

Kamil Properties

Member Of	Dial-in	Environment	Sessions
Remote control	Remote Desktop Services Profile		COM+
General	Address	Account	Profile
Telephones		Organization	

User logon name:

User logon name (pre-Windows 2000):

☐ Unlock

Account op

☐ User

☐ User

☐ Passw

☐ Store

Account e

☒ Never

☐ End o

Logon Workstations

In Computer name, type the computer's NetBIOS or Domain Name System (DNS) name.

This user can log on to:

☐ All computers

☒ The following computers

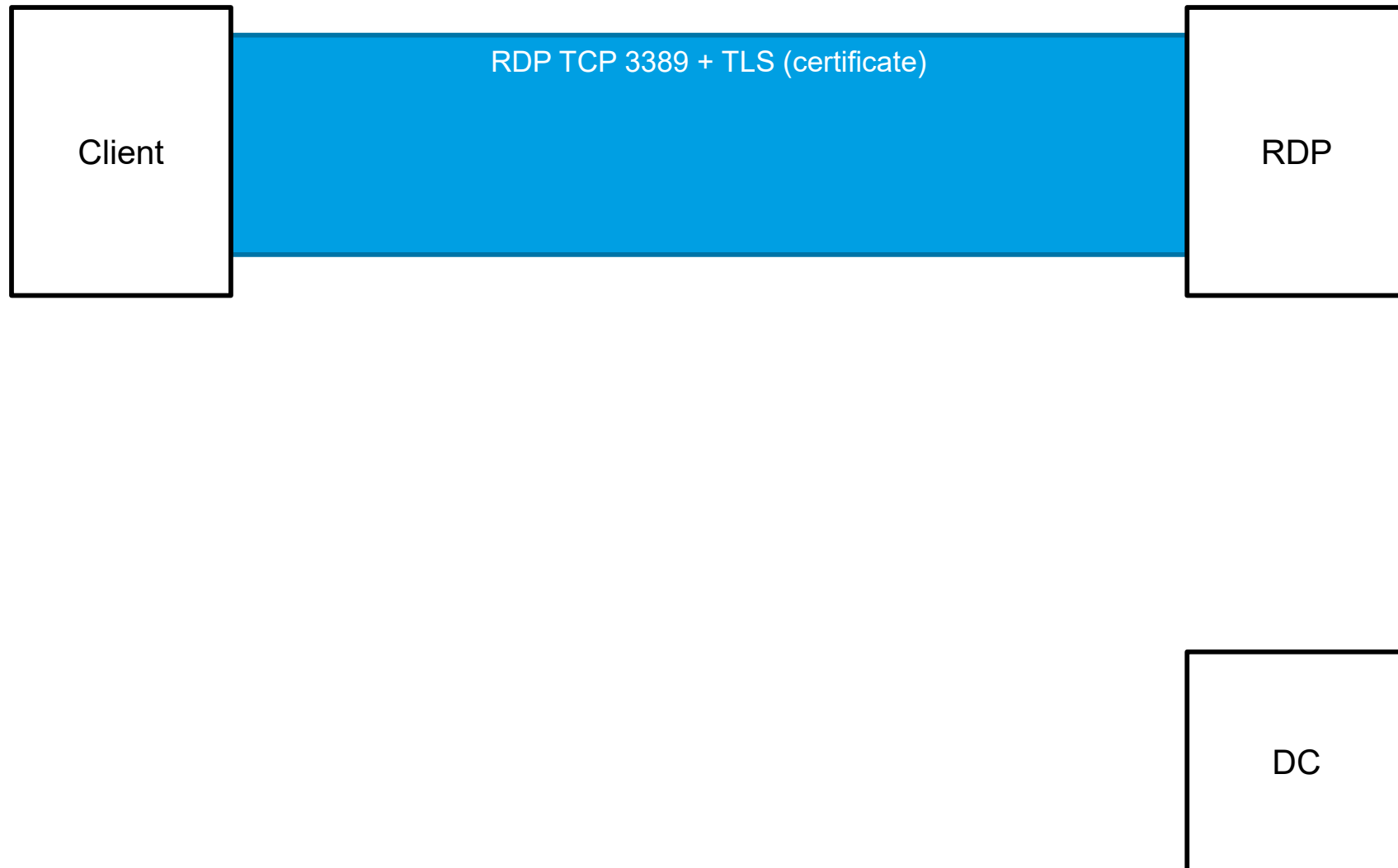
Computer name:

GPS-Client 10

GPS-SPRDP

GPS-RDP

RDP without NLA (Network Level Authentication)

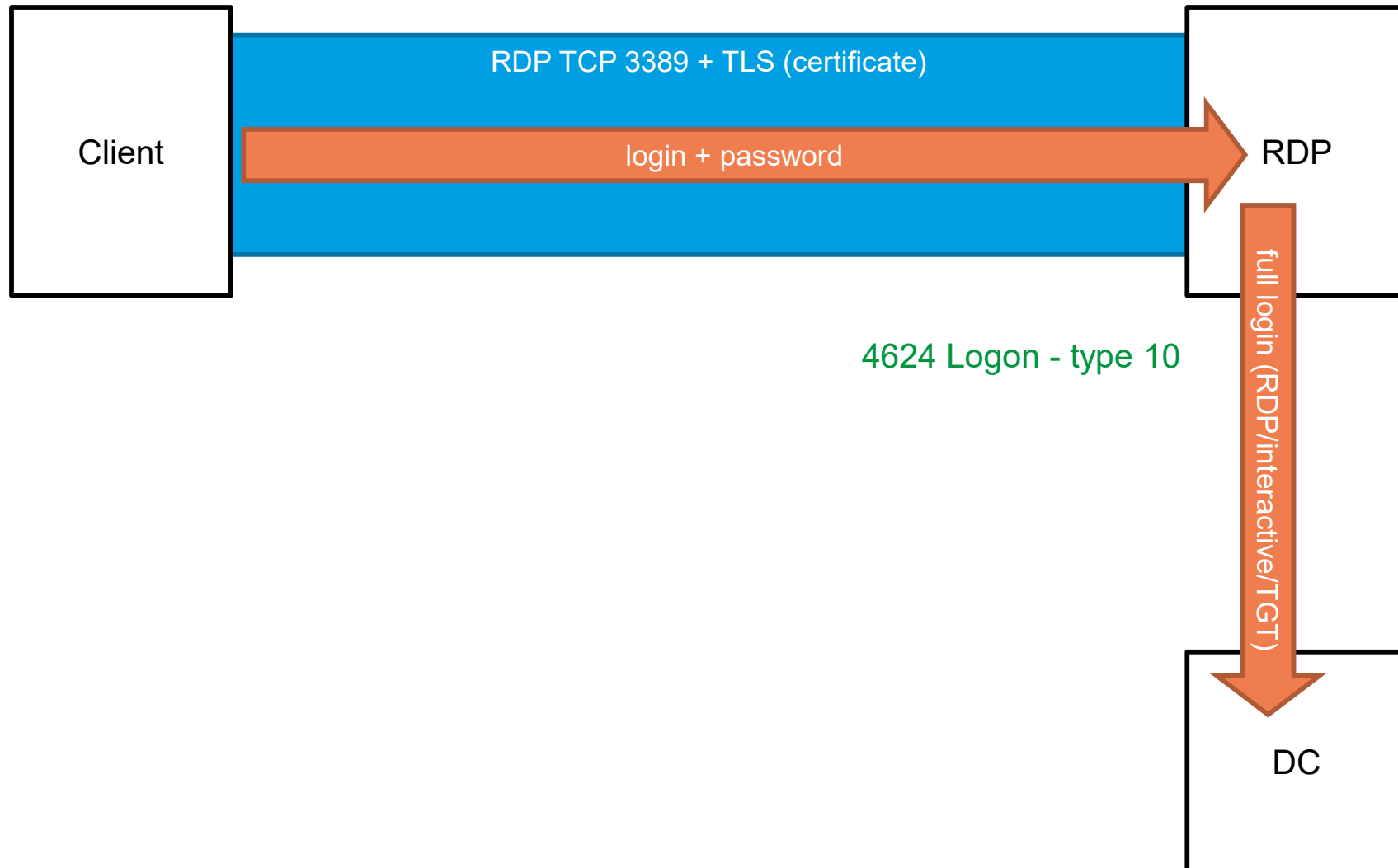


RDP without NLA (Network Level Authentication)



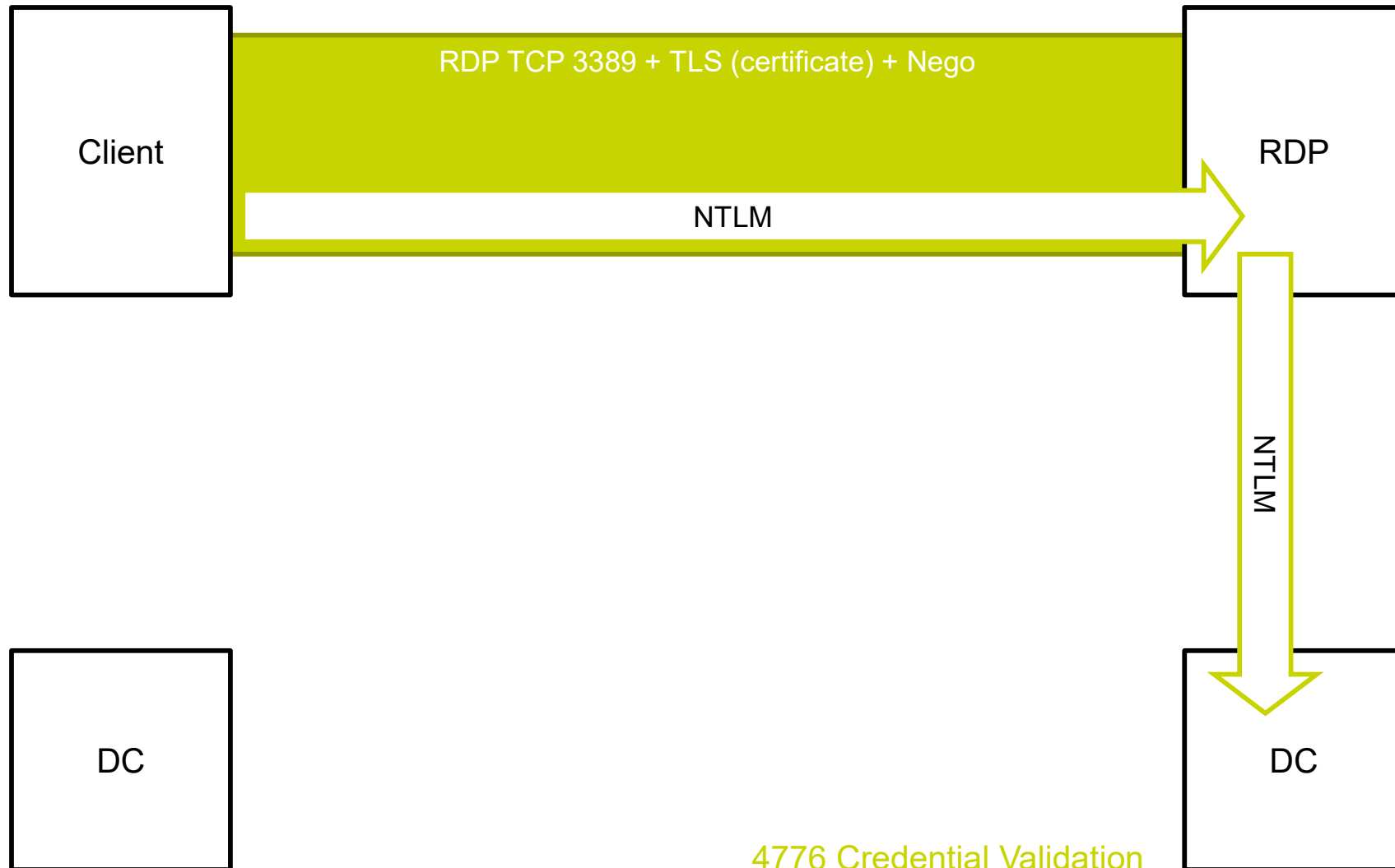
4768 Kerberos Authentication Service

RDP without NLA (Network Level Authentication)

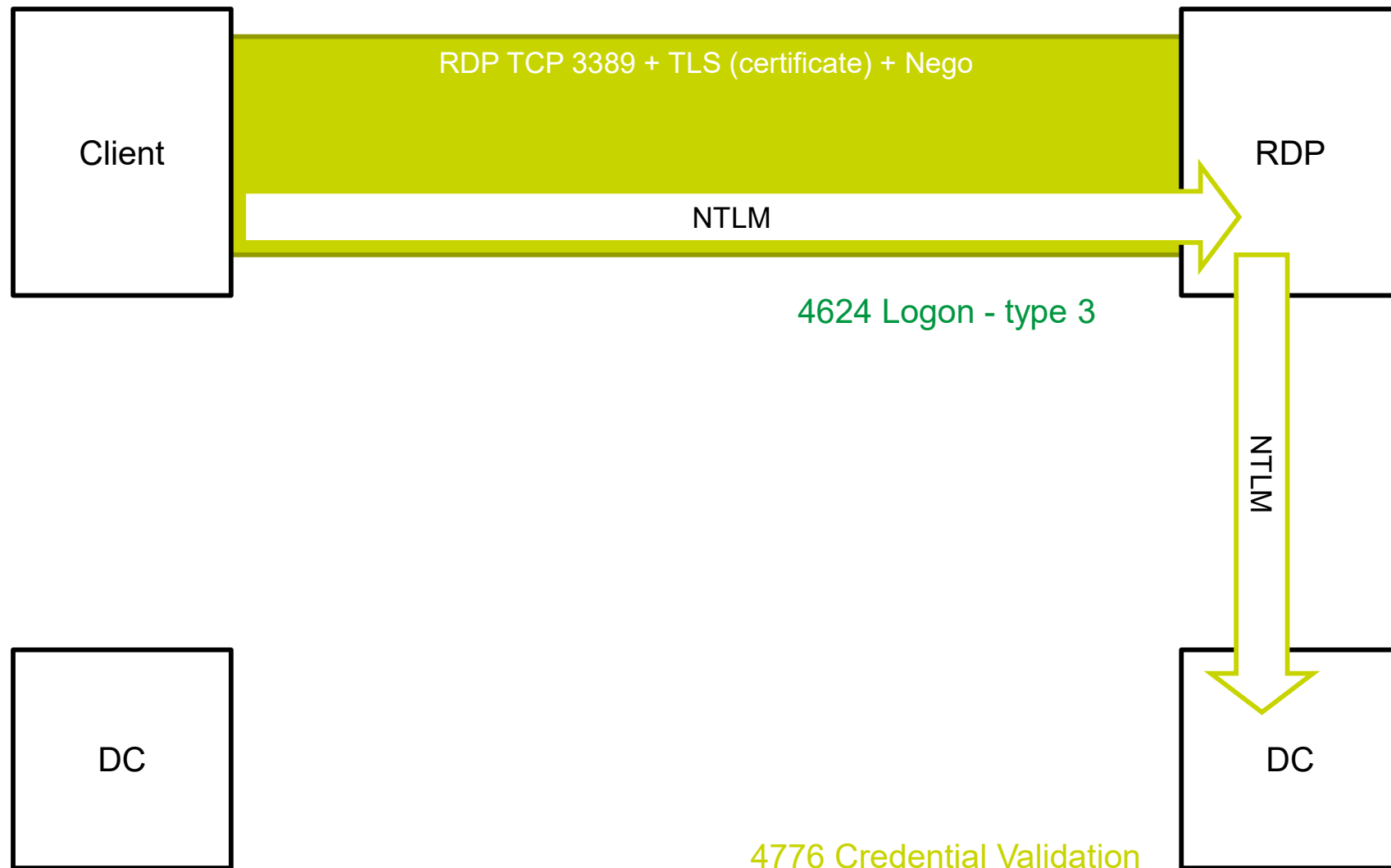


4768 Kerberos Authentication Service

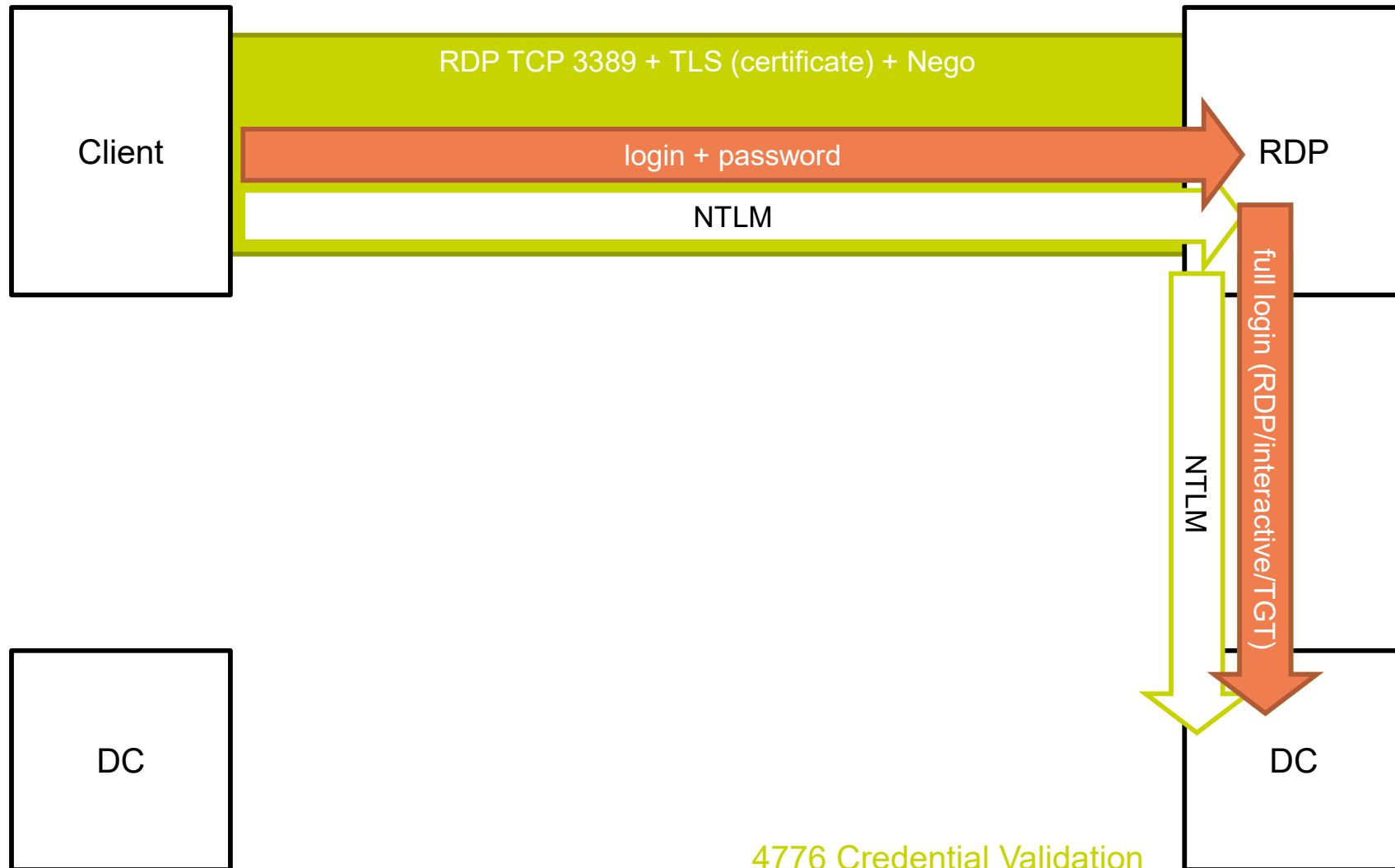
RDP with NLA (Network Level Authentication)



RDP with NLA (Network Level Authentication)



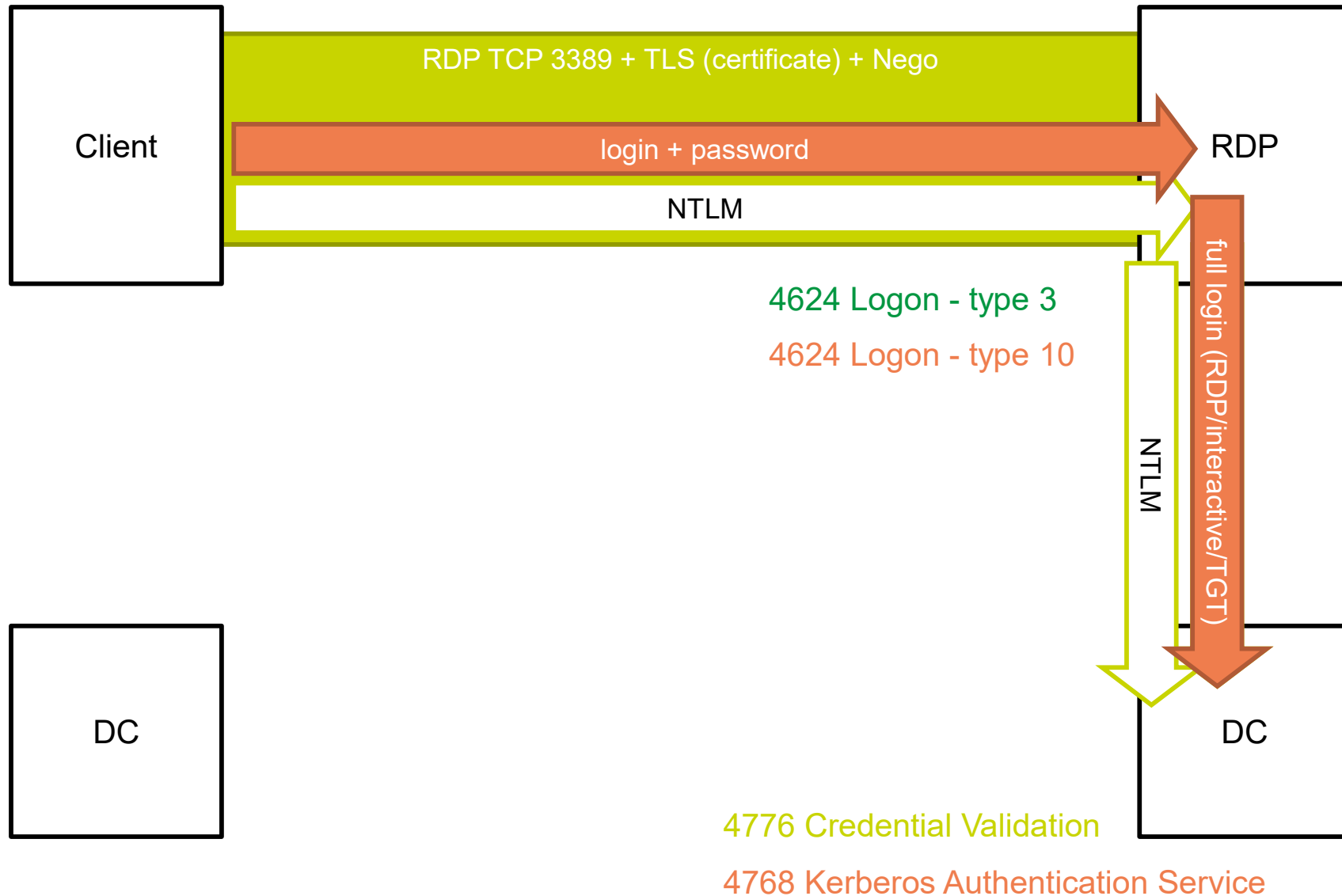
RDP with NLA (Network Level Authentication)



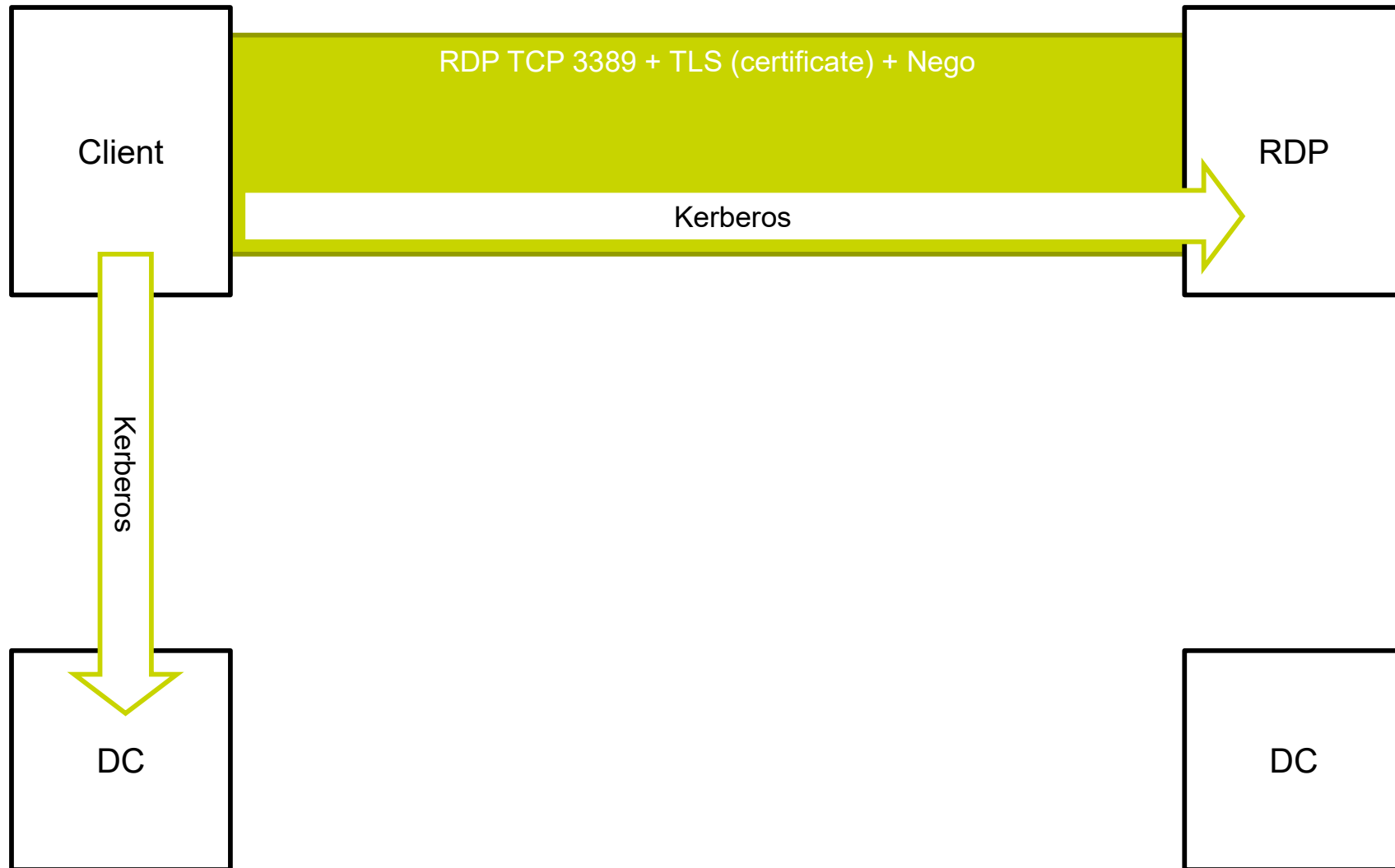
4776 Credential Validation

4768 Kerberos Authentication Service

RDP with NLA (Network Level Authentication)

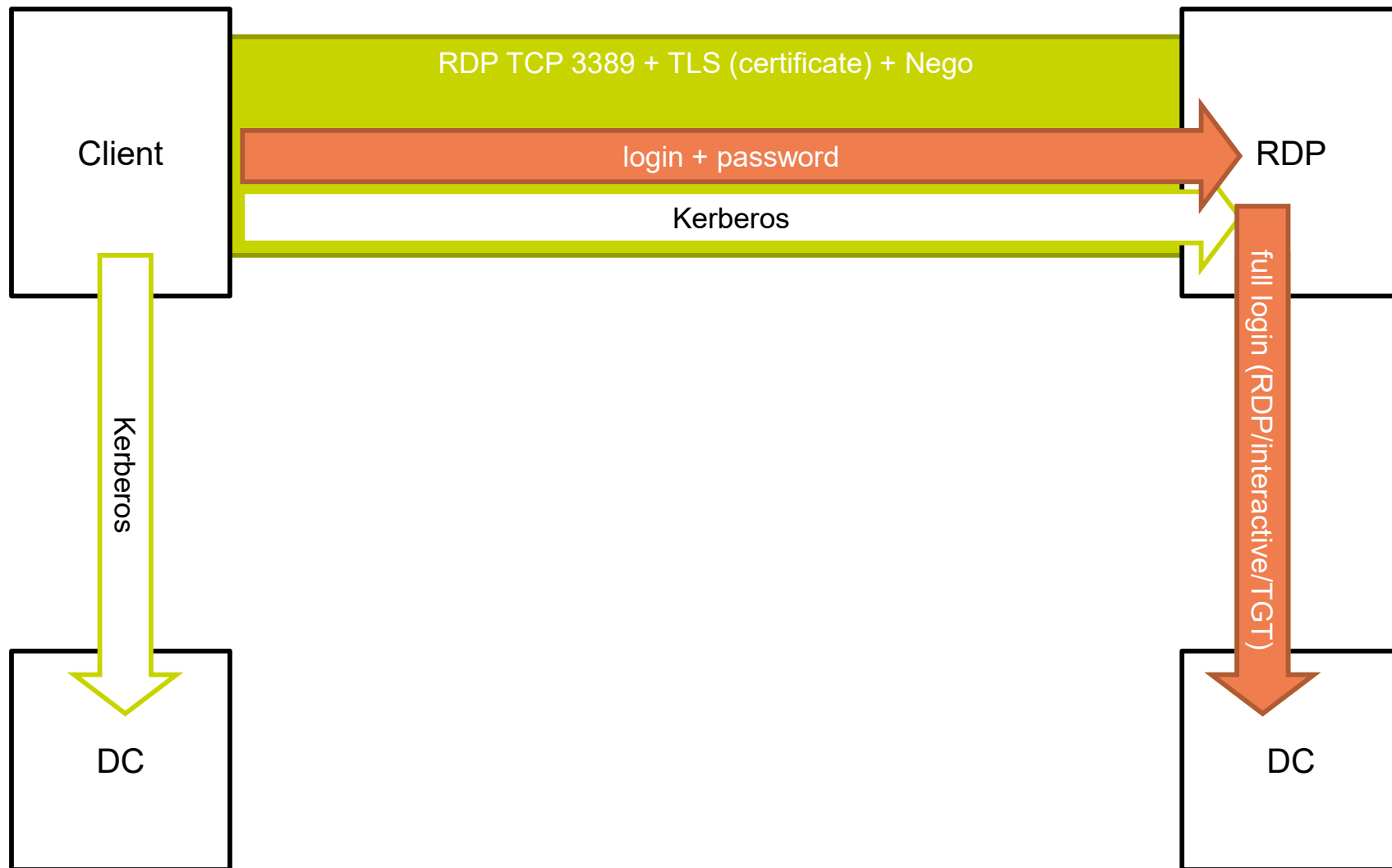


RDP with NLA (Network Level Authentication)



4768 Kerberos Authentication Service

RDP with NLA (Network Level Authentication)



4768 Kerberos Authentication Service

4768 Kerberos Authentication Service

RDP connection - the RDP server missing from the list of the "log on to" (userWorkstations)



Your account is configured to prevent you from using this computer. Please try another computer.

OK

your account is configured to prevent you from using this computer

Other user

Your account is configured to prevent you from using this PC. Please try another PC.

OK

RDP connection - the RDP client missing from the list of the "log on to" (userWorkstations) with NLA required

Remote Desktop Connection



An authentication error has occurred.
The Local Security Authority cannot be contacted

Remote computer: 10.10.0.21
This could be due to an expired password.
Please update your password if it has expired.
For assistance, contact your administrator or technical support.

An authentication error occurred. The Local Security Authority cannot be contacted

The system administrator has limited the computers you can log on with. Try logging on at a different computer. Error code 0x1107

NTLM authentication

Remote Desktop Connection



The system administrator has limited the computers you can log on with. Try logging on at a different computer. If the problem continues, contact your system administrator or technical support.

^ Hide details

OK

Error code: 0x1107
Extended error code: 0x0

Press Ctrl+C to copy.

Kerberos authentication

Disable NLA on RDP client

```
enablecredsspsupport:i:0
```

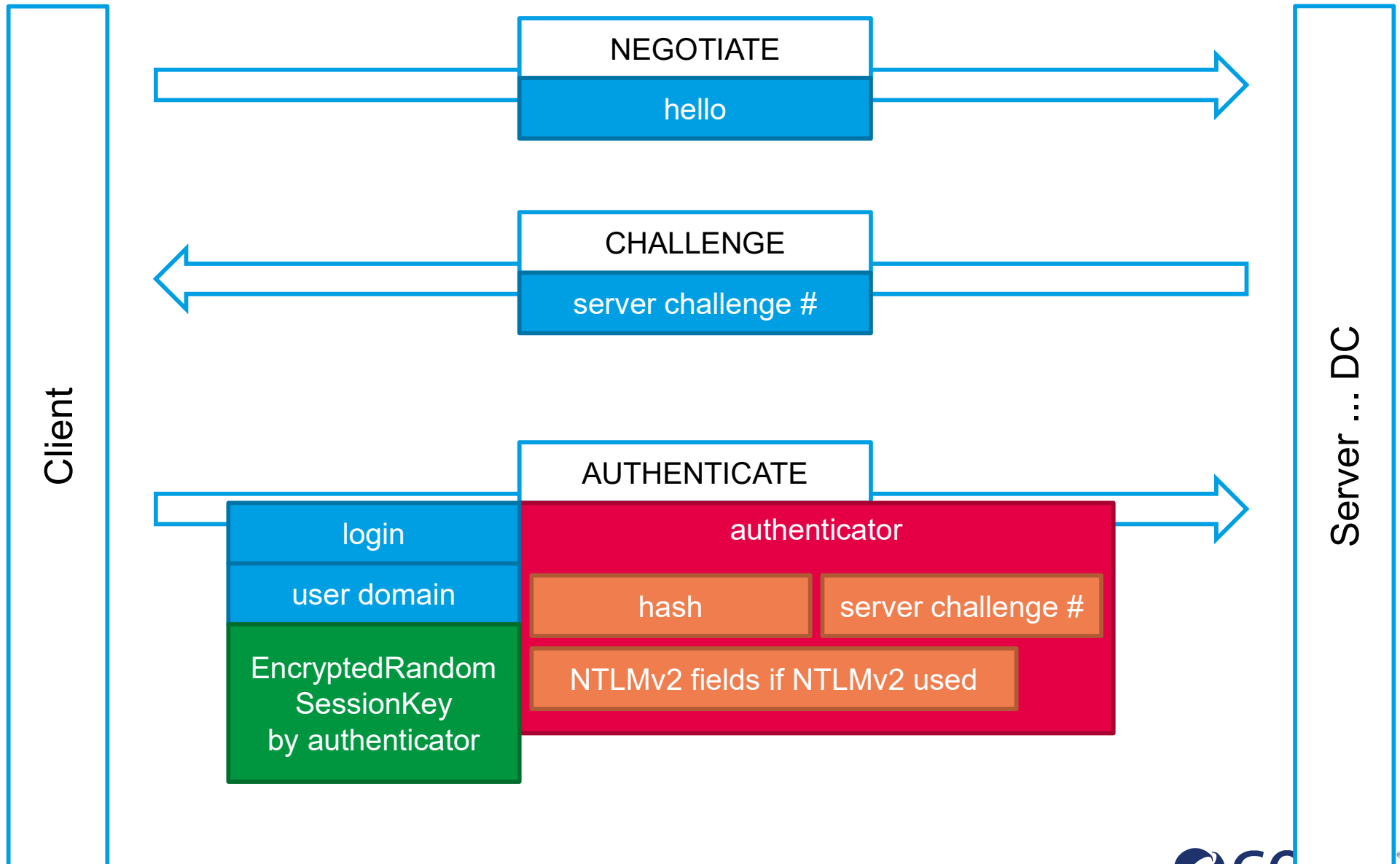
NTLMv2 time constraints

- Response calculated with client's timestamp
- Some services check the time against 30 minutes time skew
 - MS-CHAP, MS-CHAPv2
 - DCOM, WMI, Exchange, ...

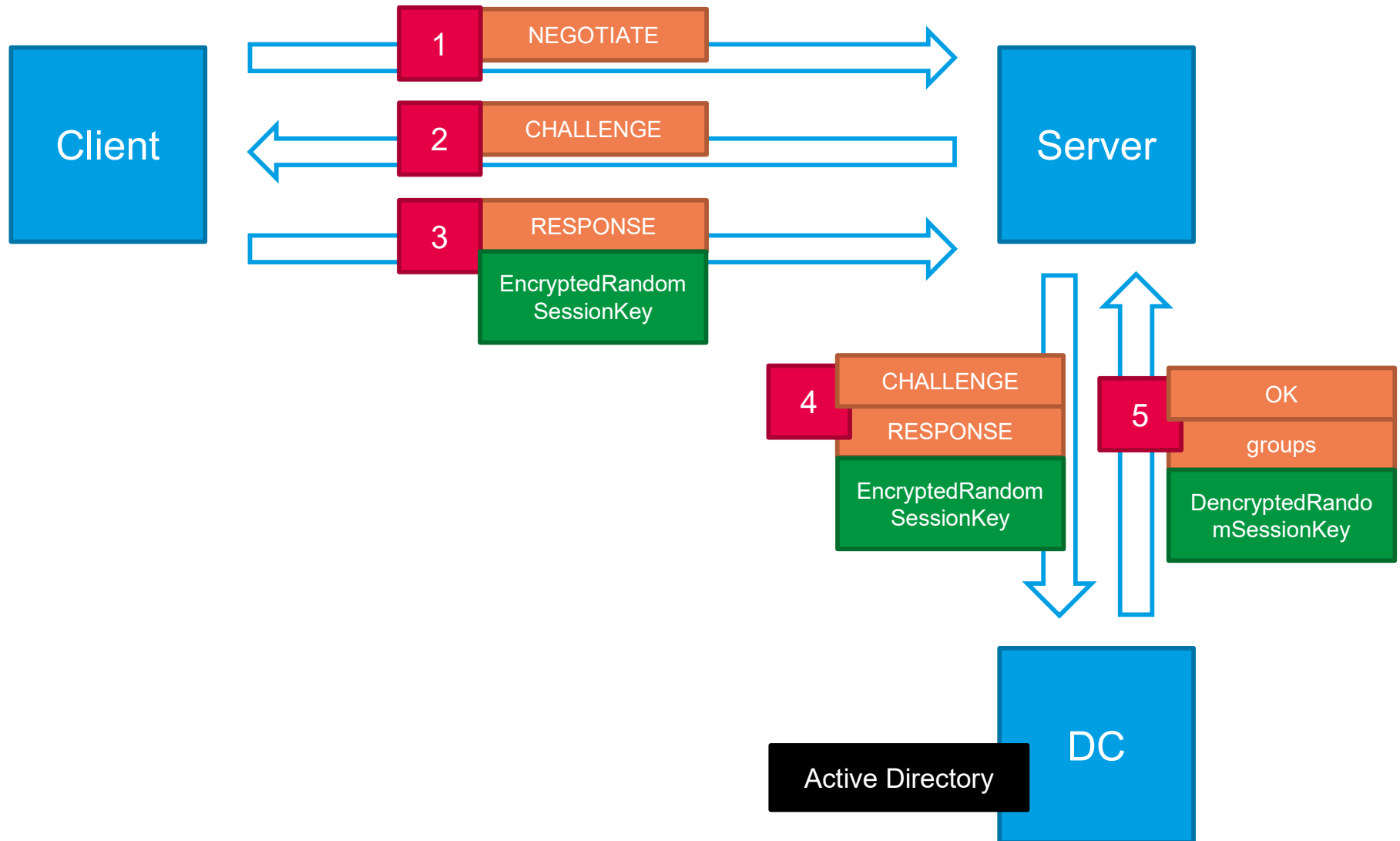
NTLM session security (~ SASL ~ GSSAPI)

- LM/NTLM/NTLMv2 has no mutual client/server authentication capabilities
 - except for NTLMv2 session security (SASL signature/encryption) connections
- No session security in HTTP
 - must use HTTPS
- Client generates random session key and encrypts it with user's password hash (response exactly)
 - if the DC/server knows the password hash, it can decrypt the session key and use it
 - mutual authentication of the client and DC + server must be domain member (no server authentication)

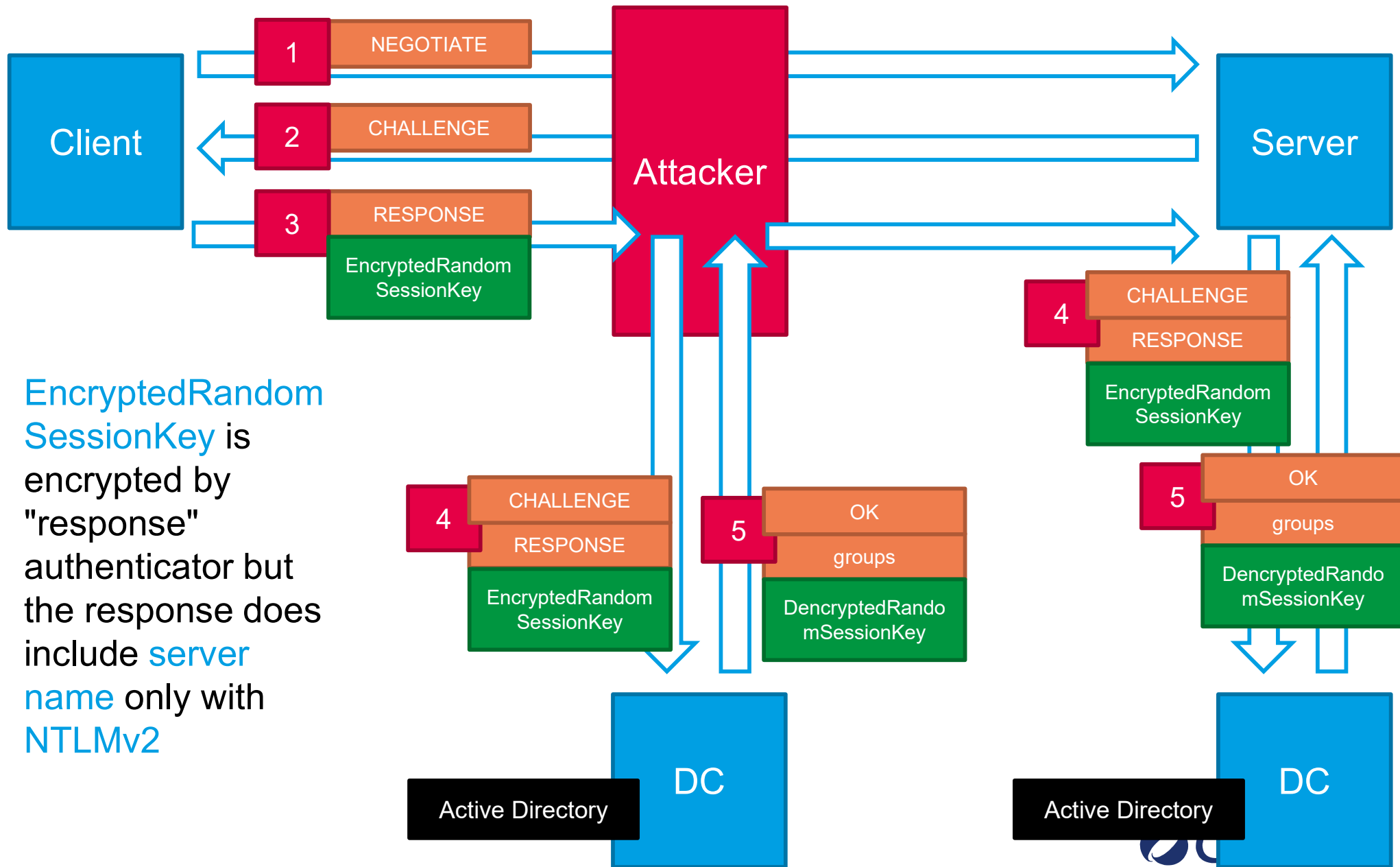
NTLMv2 session security



NTLMv2 session security with domain accounts



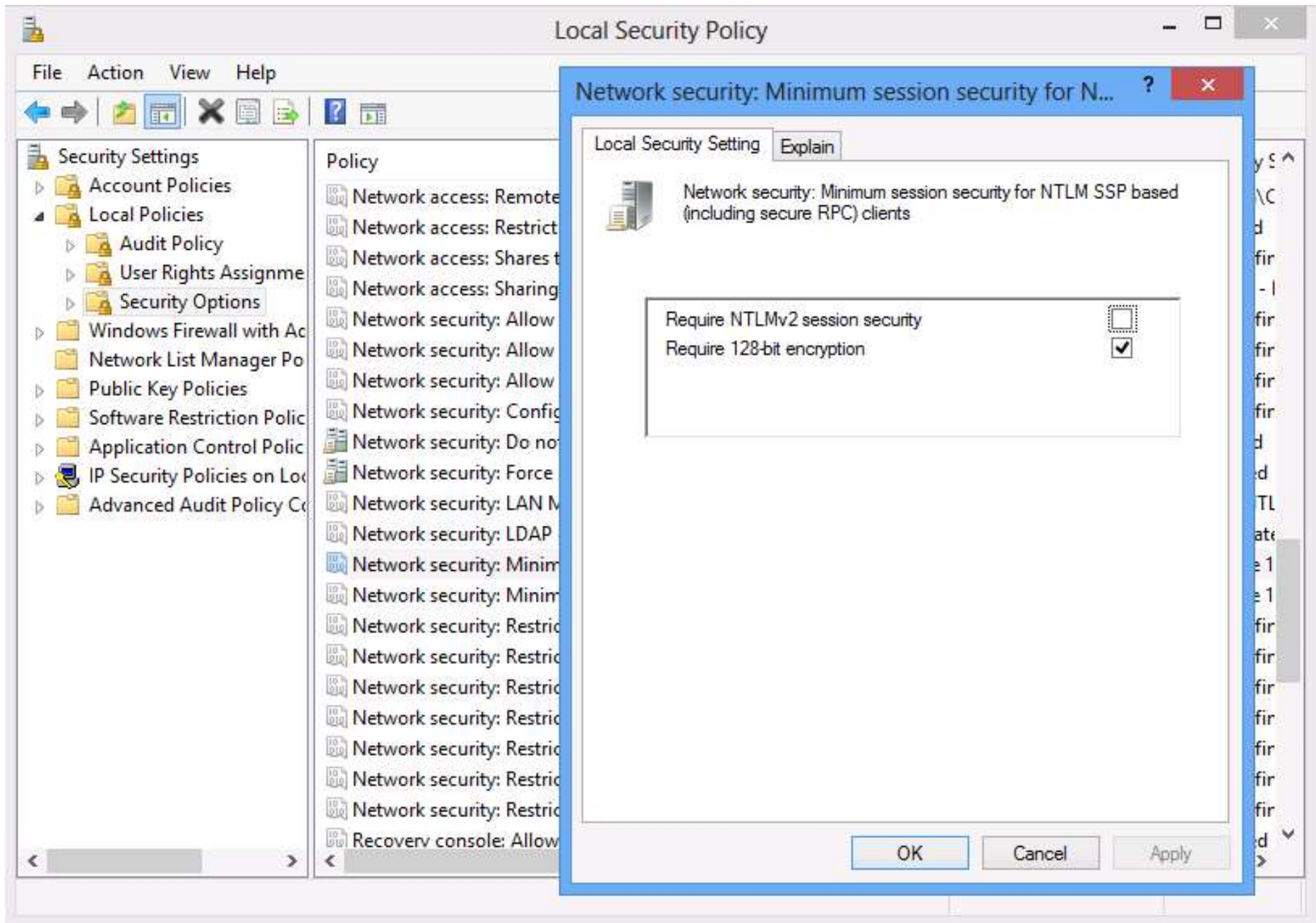
NTLMv2 session security and domain based MITM



Recap of security parameters

- LM, NTLM
 - weak algorithms
 - weak protection against replay
 - no mutual authentication
- NTLMv2 + NTLMv2 session security
 - better algorithms
 - good protections against replay
 - MITM must be domain member
- We can always combine with TLS/IPSec

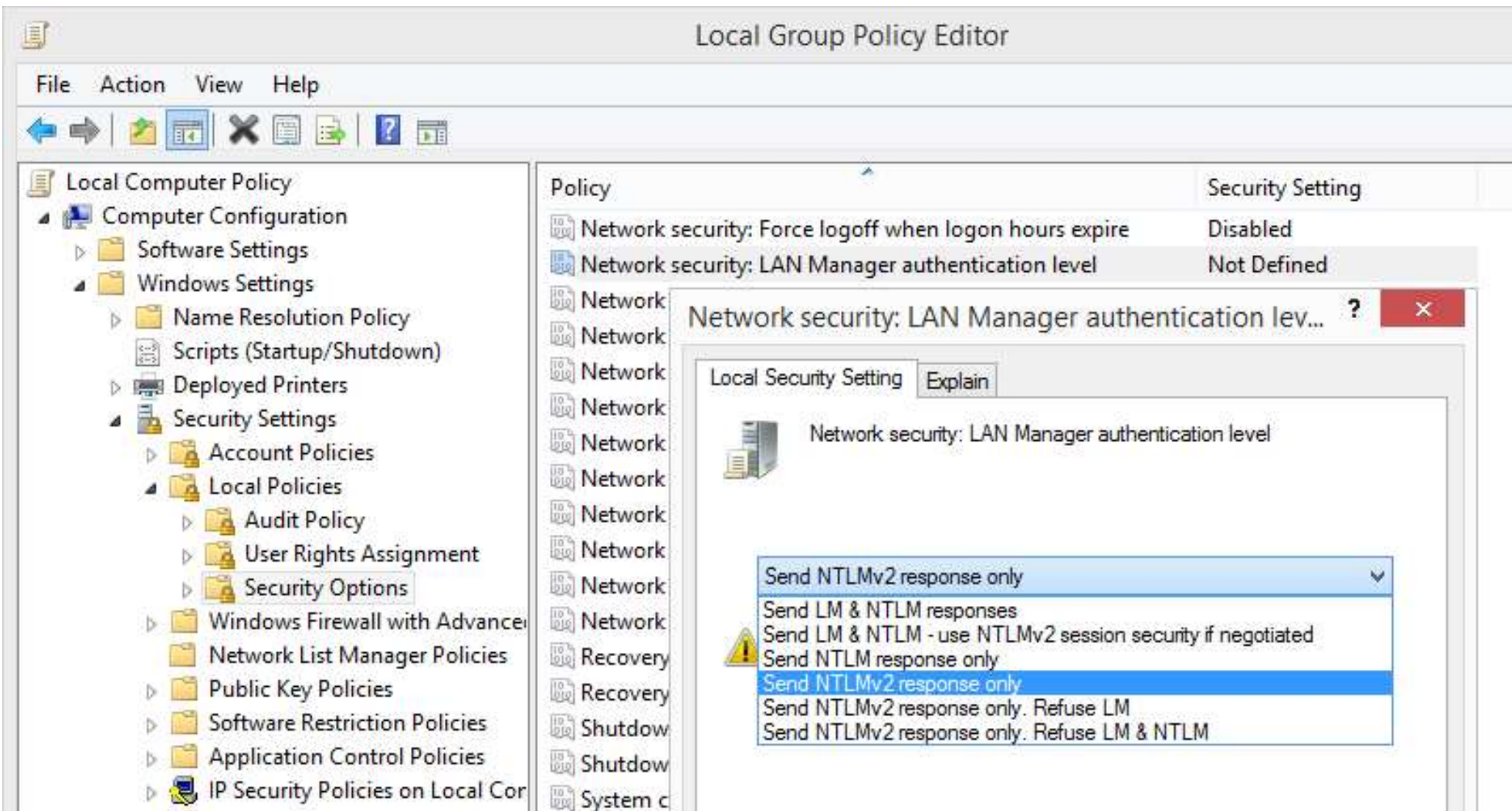
Network security: Minimum session security for NTLM SSP based clients



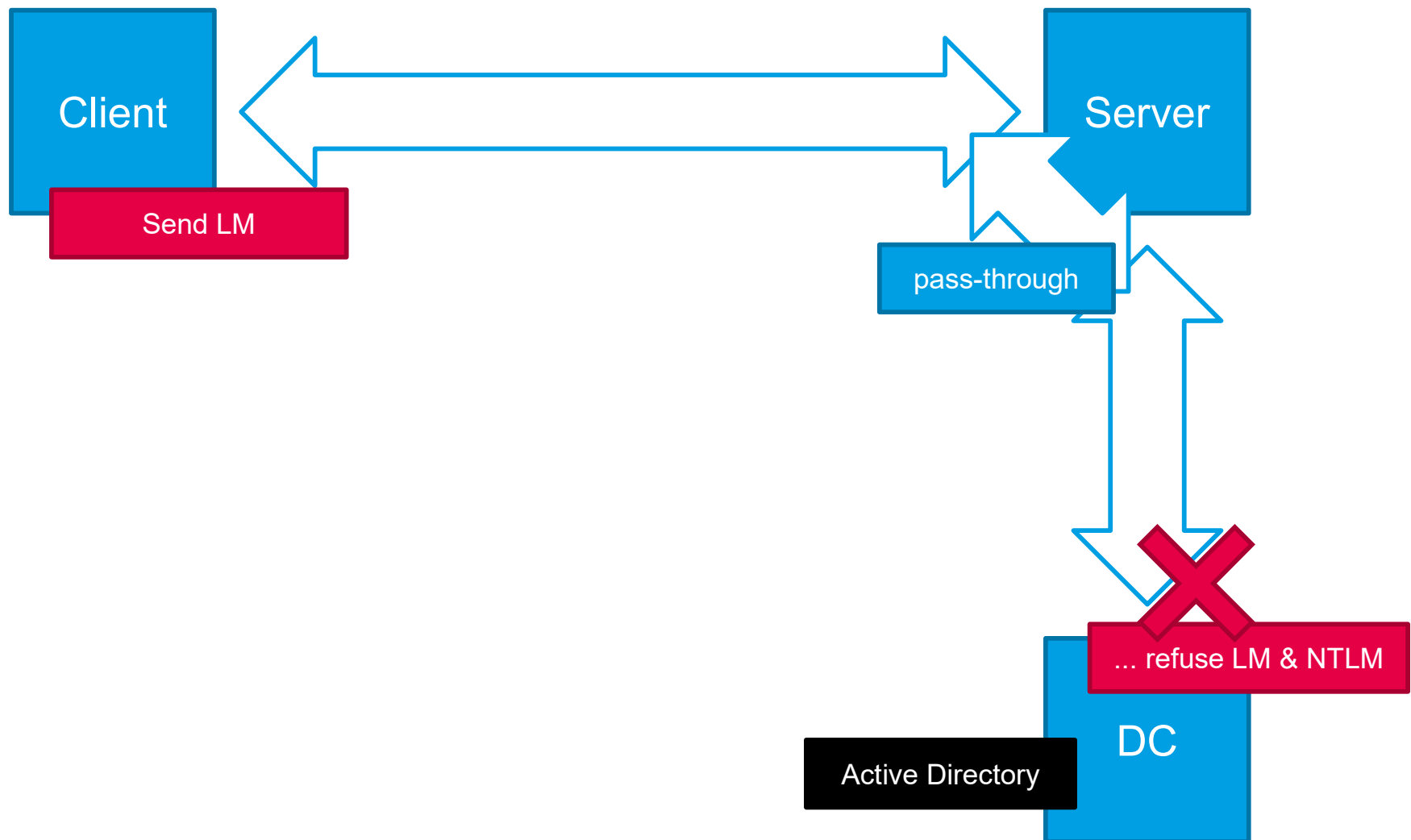
NTLM compatibility level

- No version negotiation
- Client is configured statically
 - Send LM & NTLM response
 - Send NTLM response only
 - Send NTLMv2 response
- Server can refuse older protocols
 - ... refuse LM
 - ... refuse LM & NTLM

LAN manager authentication level

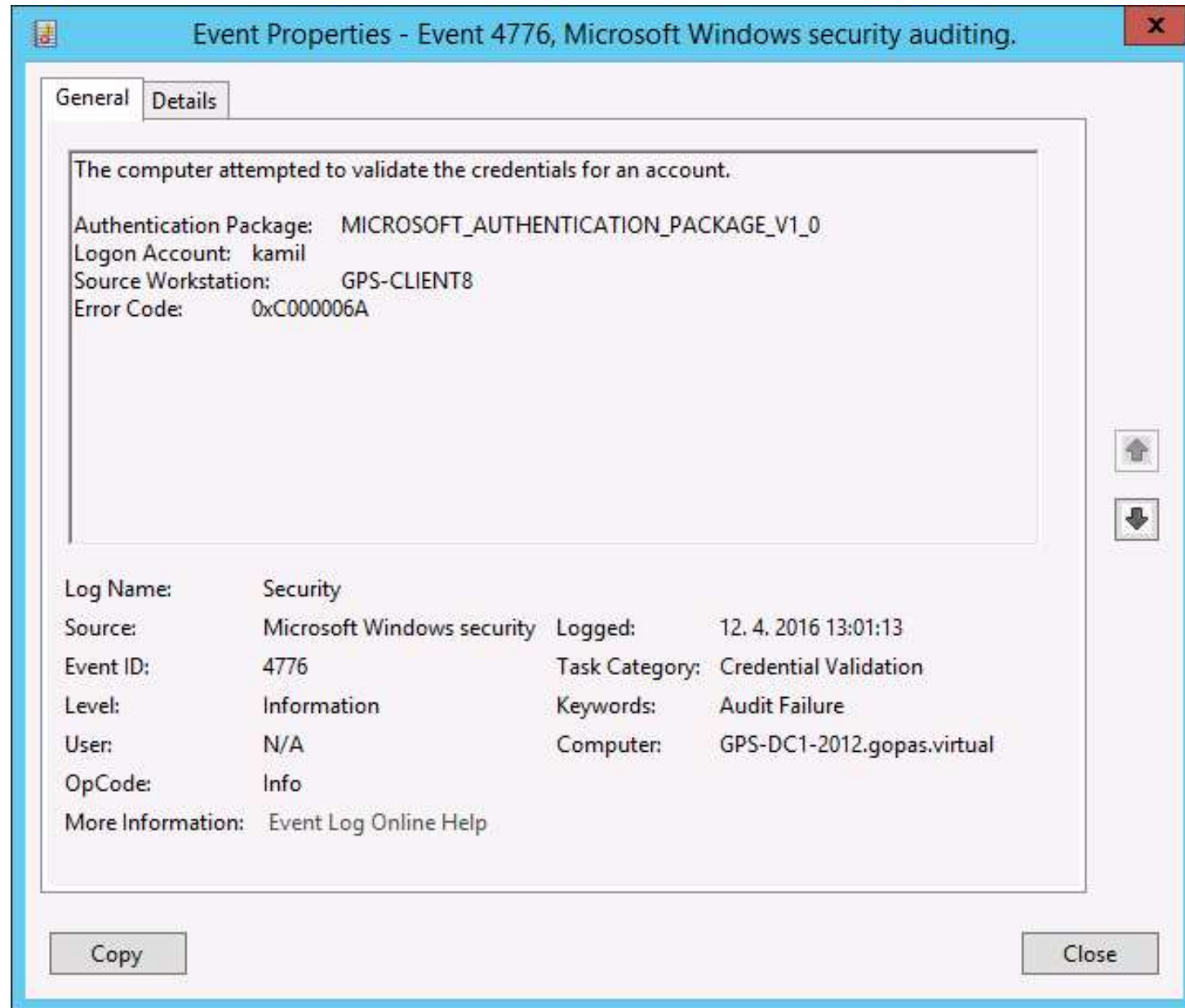


NTLM compatibility level is **client - DC** problem

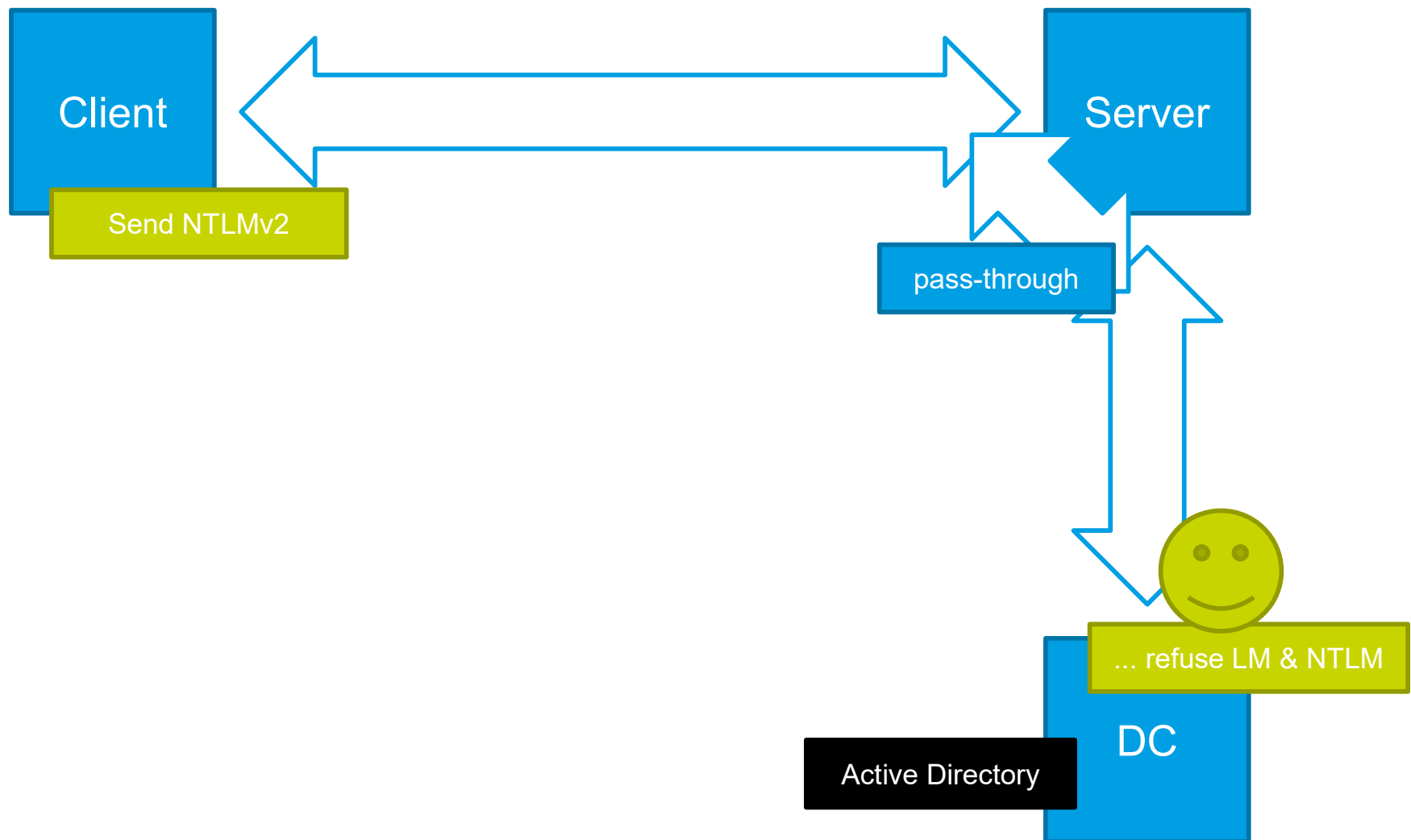


LM compatibility **account logon** failure on a DC

0xC000006A = STATUS_WRONG_PASSWORD



NTLM compatibility level is **client** - DC problem



Most secure NTLMv2 and NTLMv2 128bit session security settings

Sec: Send NTLMv2 Response Only, Refuse LM/NTLM

Data collected on: 12. 4. 2016 13:11:40

[show all](#)

Computer Configuration (Enabled)

[hide](#)

Policies

[hide](#)

Windows Settings

[hide](#)

Security Settings

[hide](#)

Local Policies/Security Options

[hide](#)

Network Security

[hide](#)

Policy

Setting

Network security: LAN Manager authentication level

Send NTLMv2 response only. Refuse LM & NTLM

Network security: Minimum session security for NTLM SSP based (including secure RPC) clients

Enabled

Require NTLMv2 session security

Enabled

Require 128-bit encryption

Enabled

Network security: Minimum session security for NTLM SSP based (including secure RPC) servers

Enabled

Require NTLMv2 session security

Enabled

Require 128-bit encryption

Enabled

User Configuration (Enabled)

[hide](#)

No settings defined.

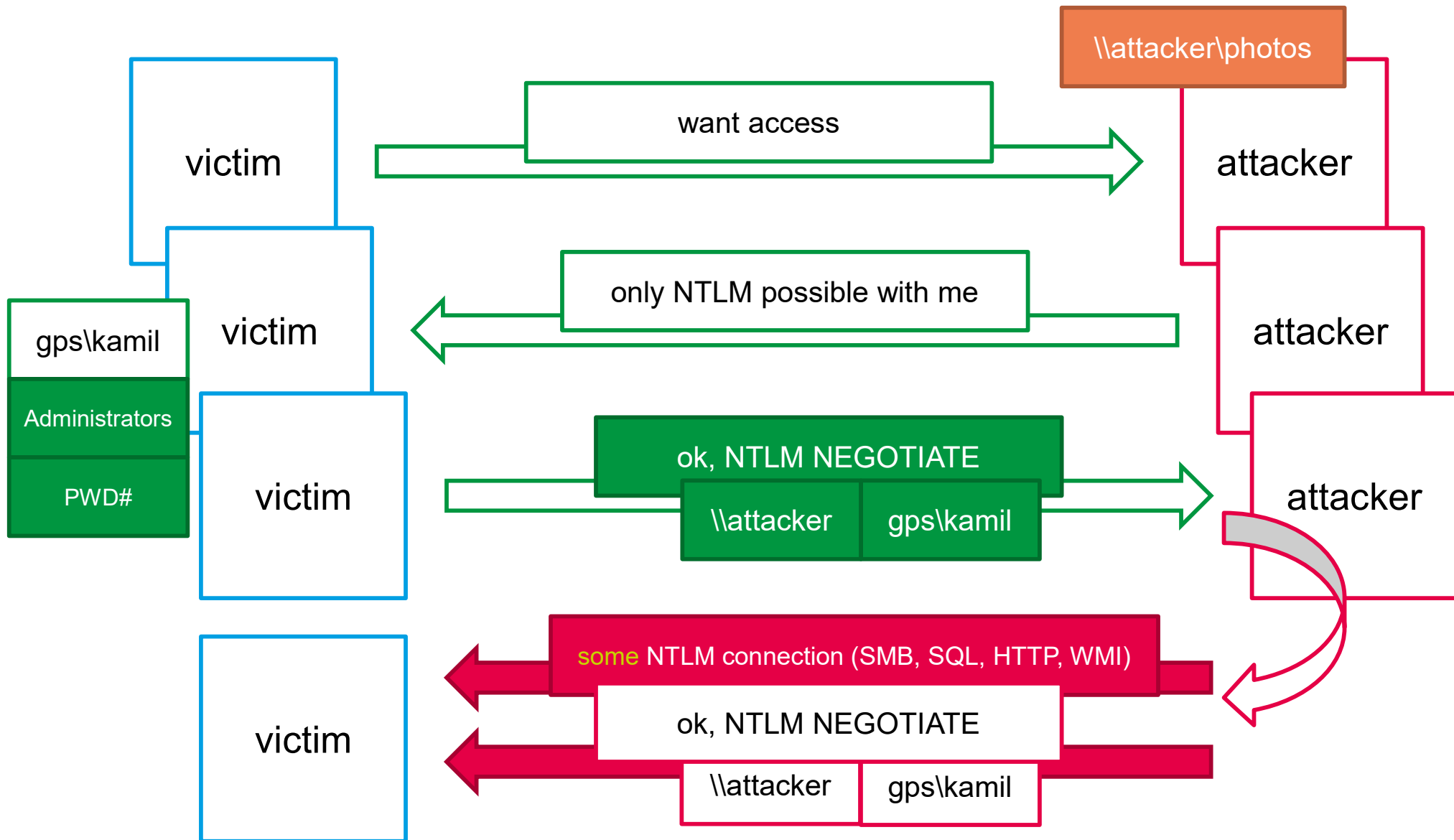
NTLM reflection (loopback) attack

- LM/NTLM/NTLMv2 has no mutual client/server authentication capabilities
 - except for NTLMv2 session security (SASL signature/encryption) connections
- social engineering or cross-site-scripting initiation
- relatively limited attack surface
 - victim is local Administrators member on its workstation
 - no firewall on the workstation
 - no SASL session security required on some connection to the workstation
 - attacker must have direct local access to the victim

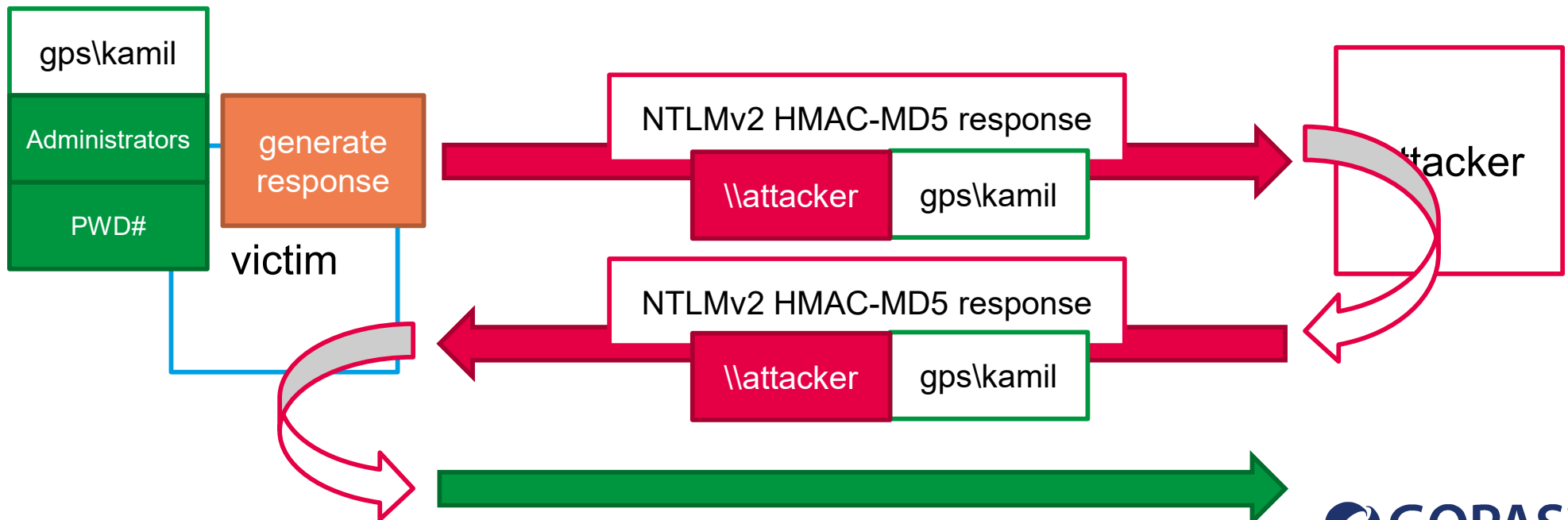
NTLM reflection (loopback) attack #1



NTLM reflection (loopback) attack #2



NTLM reflection (loopback) attack #3

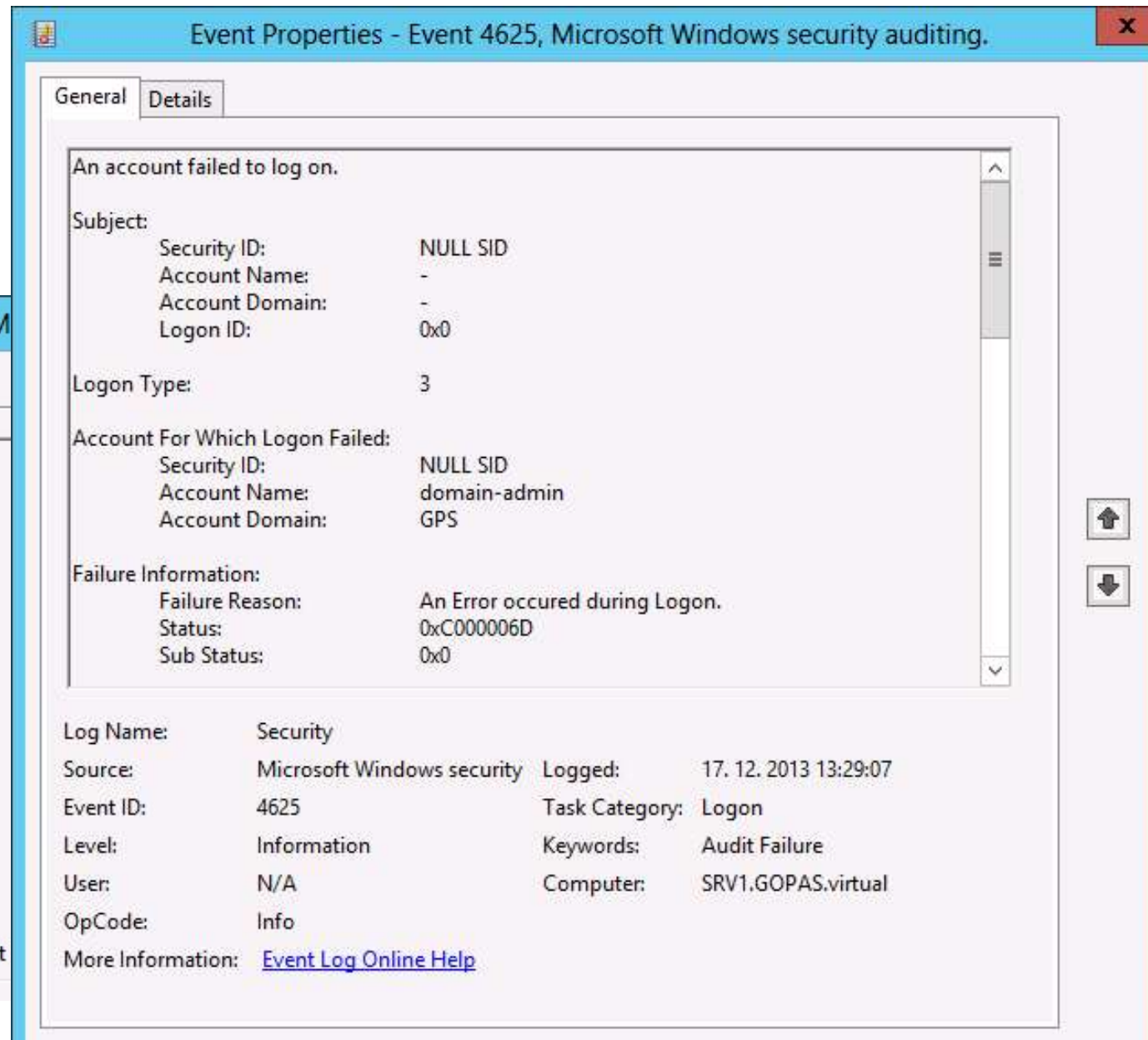
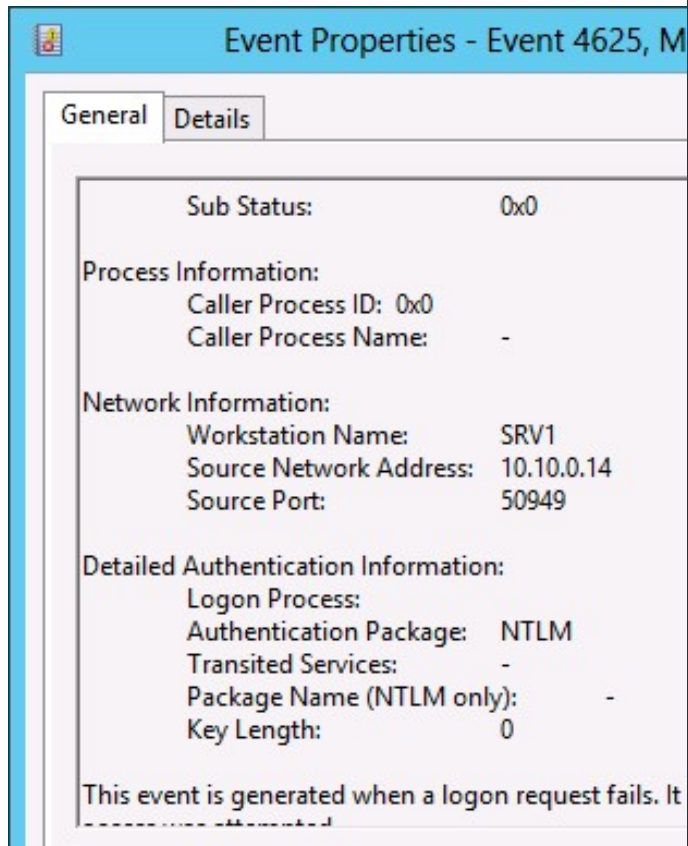


Loopback Check

- Loopback access with NTLM on alias
 - LSASS has the same NTLM token with different server name in cache
- HKLM\System\CCS\Control\LSA\MSV1_0
 - BackConnectionHostNames = MULTI_SZ
 - always type both short and FQDN
- HKLM\System\CCS\Control\LSA
 - DisableLoopbackCheck = DWORD = 1
 - do not do this!

Loopback Check and **logon** audit failure

Sub Status = 0 and Status = 0xC000006D



Alternative computer names

```
netdom computername localhost  
/add:canteen.gopas.virtual  
/userD:gps\domain-admin  
/passwordD:Pa$$w0rd
```

- Solves automatically
 - NTLM loopback-check
 - DNS A record
 - msDS-AdditionalDnsHostName
 - Kerberos SPNs
 - DisableLoopbackCheck for SMBv1

NTLM pass-the-hash

Select mimikatz 2.2.0 x64 (oe.eo)

```
C:\>
C:\>t:\mimikatz\v2.2-20200918\x64\mimikatz.exe

.#####.   mimikatz 2.2.0 (x64) #19041 Sep 18 2020 19:18:29
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords
```

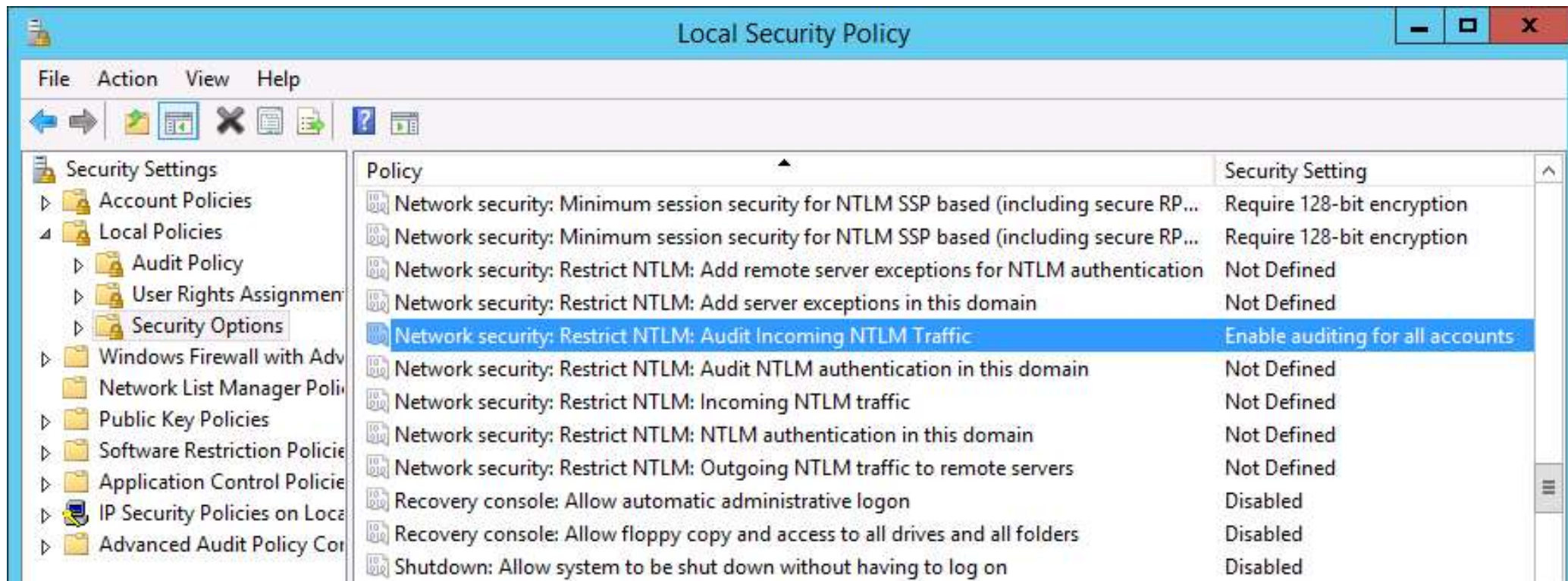
Select mimikatz 2.2.0 x64 (oe.eo)

```
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz # sekurlsa::pth /user:domain-admin /domain:gps /ntlm:92937945b518814341de3f726500d4ff /run:cmd
user      : domain-admin
```

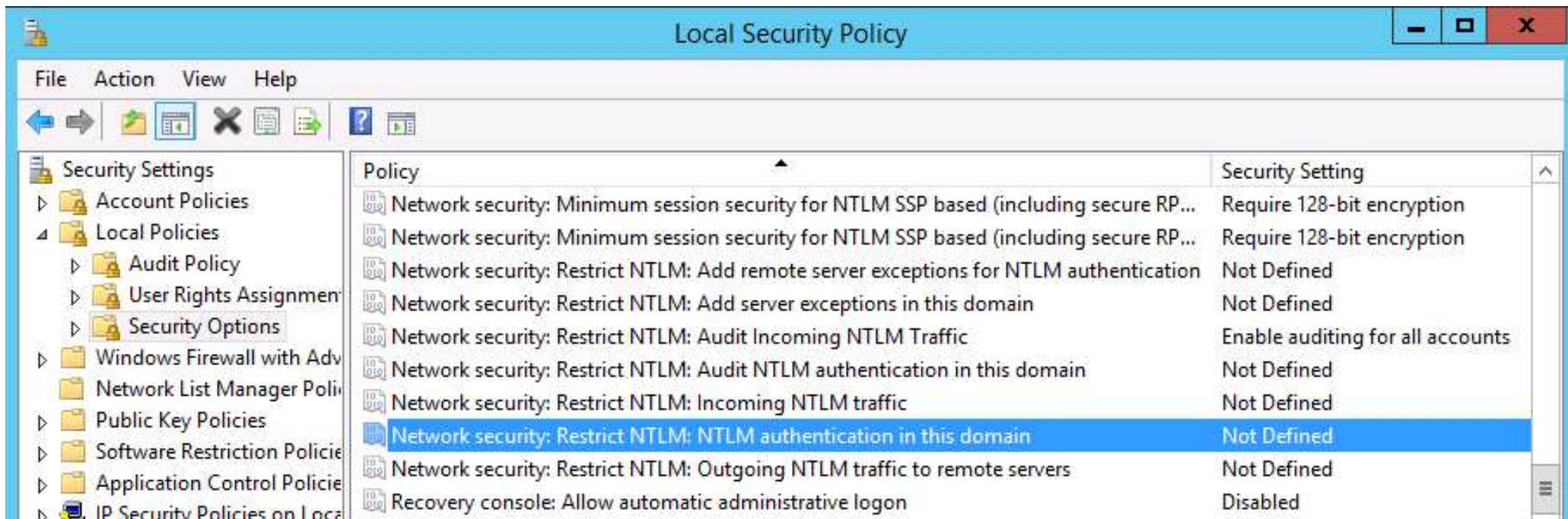
Disabling/auditing NTLM (since 7/2008R2)

- Network Security: Restrict NTLM: Outgoing NTLM traffic to remote servers
 - on the **clients** from which the connection starts
- Network Security: Restrict NTLM: Audit incoming NTLM traffic
 - on the **resource server**
- Network Security: Restrict NTLM: Audit NTLM authentication in this domain
 - on the **DC** or resource server in case of local accounts

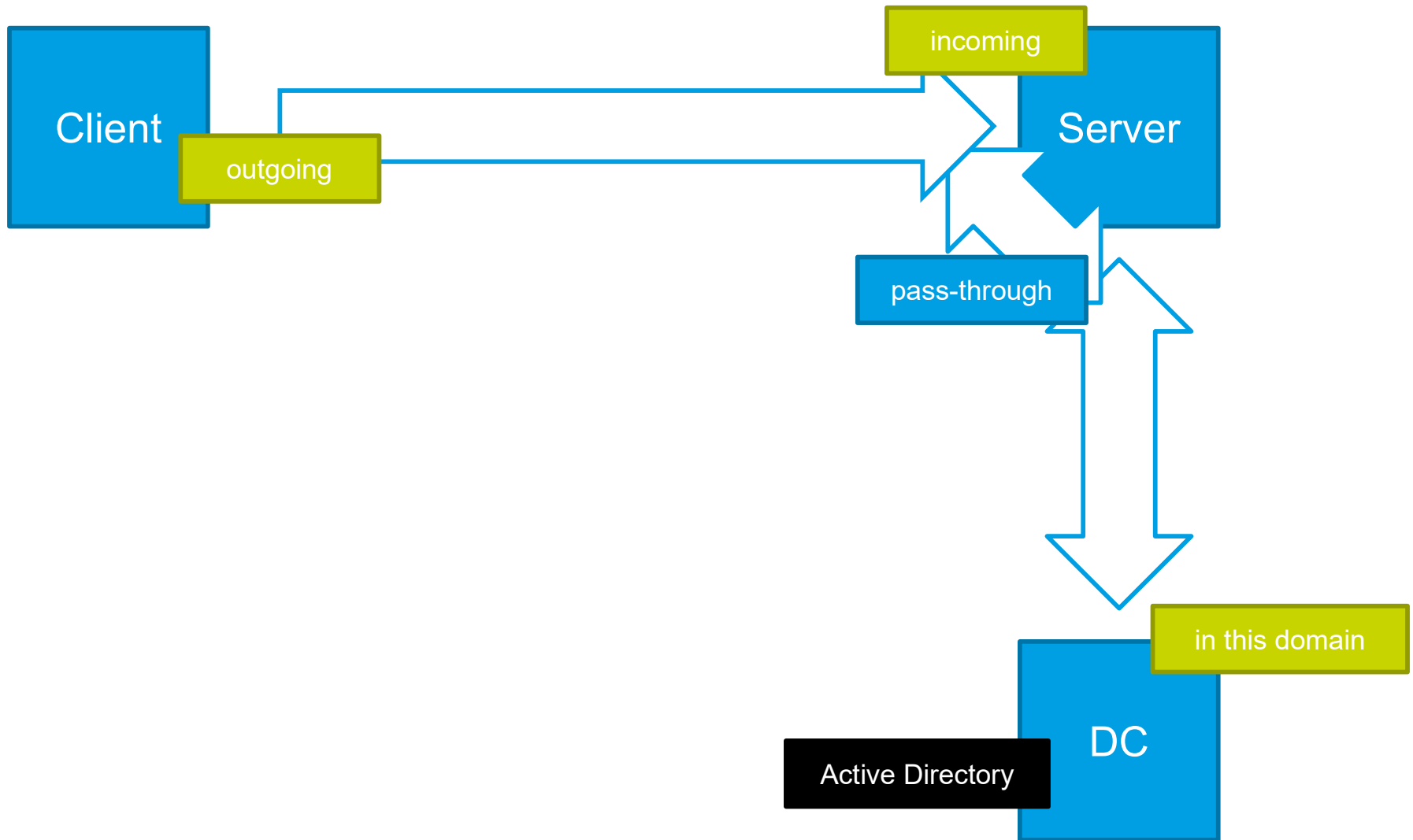


Disabling/auditing NTLM

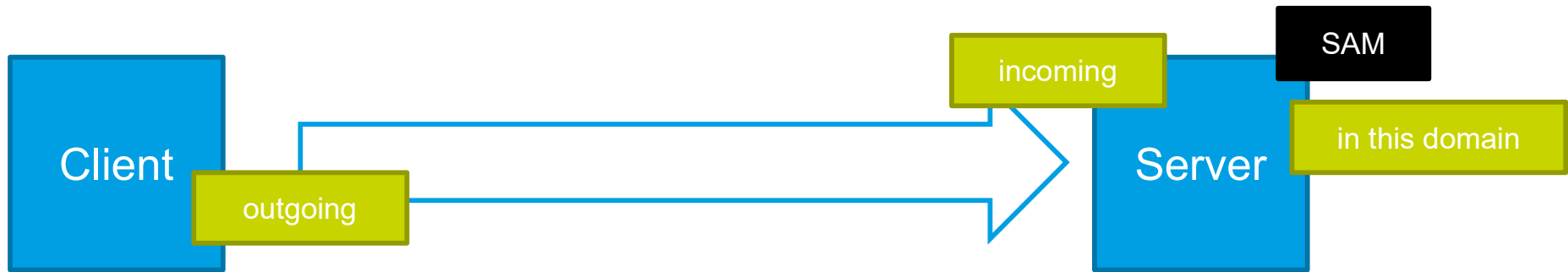
- Network Security: Restrict NTLM: Outgoing NTLM traffic to remote servers
 - on the **clients** from which the connection starts
- Network Security: Restrict NTLM: Incoming NTLM traffic
 - on the **resource server**
- Network Security: Restrict NTLM: NTLM authentication in this domain
 - on the **DCs** or resource servers in case of local accounts



NTLM auditing or disabling (domain accounts)



NTLM auditing or disabling (local accounts)



NTLM audit example (EventID 8003)

- Log name: Microsoft-Windows-NTLM/Operational, Event ID: 8003, Category: Auditing NTLM, ...



NTLM audit examples (EventID 8001, 8002, 8004)

Event Properties - Event 8001, NTLM

General Details

NTLM client blocked audit: Audit outgoing NTLM authentication traffic that would be blocked.
Target server: HTTP/intranet.gopas.virtual
Supplied user: (NULL)
Supplied domain: (NULL)
PID of client process: 6348
Name of client process: C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
LUID of client process: 0xE0D57F
User identity of client process: kamil
Domain name of user identity of client process: GPS
Mechanism OID: (NULL)

client (outgoing)

Event Properties - Event 8002, NTLM

General Details

NTLM server blocked audit: Audit Incoming NTLM Traffic that would be blocked
Calling process PID: 3408
Calling process name: C:\Windows\System32\inetssrv\w3wp.exe
Calling process LUID: 0x1E93F42
Calling process user identity: intranet AppPool
Calling process domain identity: IIS APPPOOL
Mechanism OID: (NULL)

server (incoming)

Event Properties - Event 8004, Security-Netlogon

General Details

Domain Controller Blocked Audit: Audit NTLM authentication to this domain controller.
Secure Channel name: GPS-WEB
User name: kamil
Domain name: GPS
Workstation name: GPS-CLIENT10
Secure Channel type: 2

DC (in this domain)

NTLM audit examples (EventID 8001, 8002, 8004)

Event Properties - Event 8001, NTLM

client (outgoing)

General Details

NTLM client blocked audit: Audit outgoing NTLM authentication traffic that would be blocked.
Target server: MSSQLSvc/GPS-DATA.gopas.virtual:50849
Supplied user: (NULL)
Supplied domain: (NULL)
PID of client process: 4128
Name of client process: C:\Program Files (x86)\Microsoft Office\Office15\EXCEL.EXE
LUID of client process: 0x92265B
User identity of client process: kamil
Domain name of user identity of client process: GPS
Mechanism OID: (NULL)

Event Properties - Event 8003, NTLM

server (incoming)

General Details

NTLM server blocked in the domain audit: Audit NTLM authentication in this domain
User: kamil
Domain: GPS
Workstation: GPS-CLIENT10
PID: 3064
Process: F:\SQL-HRAGENDA\MSSQL11.HRAGENDA\MSSQL\Binn\sqlservr.exe
Logon type: 3
InProc: true
Mechanism: (NULL)

Event Properties - Event 8004, Security-Netlogon

DC (in this domain)

General Details

Domain Controller Blocked Audit: Audit NTLM authentication to this domain controller.
Secure Channel name: GPS-DATA
User name: kamil
Domain name: GPS
Workstation name: GPS-CLIENT10
Secure Channel type: 2

Allow Cryptographic Algorithms Compatible with Windows NT 4.0

- Windows 2008 do not support NT 4.0 secure channel algorithms
- 0xC0000388 = STATUS_DOWNGRADE_DETECTED

101.9361141	10.0.0.5	10.0.0.4	TCP	TCP:Flags=...A..., SrcPort=56284, DstPort=Microsoft-DS(445), PayloadLen=0, Seq=2784958250, Ack=2749708921, Win=2680
101.9365483	10.0.0.5	10.0.0.4	MSRPC	MSRPC:c/o Bind: Netlogon(NRPC) UUID{12345678-1234-ABCD-EF00-01234567CFFB} Call=0x1AD Assoc Grp=0x0 Xmit=0x10B8 Recv=0x10B8
101.9366200	10.0.0.4	10.0.0.5	MSRPC	MSRPC:c/o Bind Ack: Call=0x1AD Assoc Grp=0xA1A7 Xmit=0x10B8 Recv=0x10B8
101.9374617	10.0.0.5	10.0.0.4	NRPC	NRPC:NetrServerReqChallenge Request, PrimaryName = \\LENIA1, ComputerName = NAS
101.9375477	10.0.0.4	10.0.0.5	NRPC	NRPC:NetrServerReqChallenge Response, ReturnValue = Success
101.9414102	10.0.0.5	10.0.0.4	NRPC	NRPC:NetrServerAuthenticate2 Request, PrimaryName = \\LENIA1, AccountName = NAS\$, ComputerName = NAS, SecureChannelType = Workstation
101.9414721	10.0.0.4	10.0.0.5	NRPC	NRPC:NetrServerAuthenticate2 Response, NegotiateFlags = 0x400701FF, ReturnValue = 0xC0000388 - STATUS_DOWNGRADE_DETECTED
101.9420491	10.0.0.5	10.0.0.4	SMR	SMR:c/o Close: File = 0x40002 FileName=\\MFT1 0x00000000#23

Protected users (since 2012R2/8.1 machines) do not have NTLM credentials

The screenshot shows the 'Active Directory Users and Computers' console. The left pane displays a tree view with 'gopas.virtual' expanded, showing folders like 'BuiltIn', 'Company', 'Computers', 'Domain Controllers', 'ForeignSecurityPrincipals', 'LostAndFound', 'Managed Service Accounts', 'Program Data', 'System', 'Users', 'NTDS Quotas', and 'TPM Devices'. The right pane lists several security groups, with 'Protected Users' selected. Below this, the 'Protected Users Properties' dialog box is open, showing the 'Members' tab. The 'Members' list contains two entries: 'Admin Accounts' and 'Service Accounts', both with the path 'gopas.virtual/Company/Service'.

Name	Type
WinRMRemoteWMIUsers__	Security Group - Domain Local
Schema Admins	Security Group - Universal
Read-only Domain Controllers	Security Group - Global
RAS and IAS Servers	Security Group - Domain Local
Protected Users	Security Group - Global

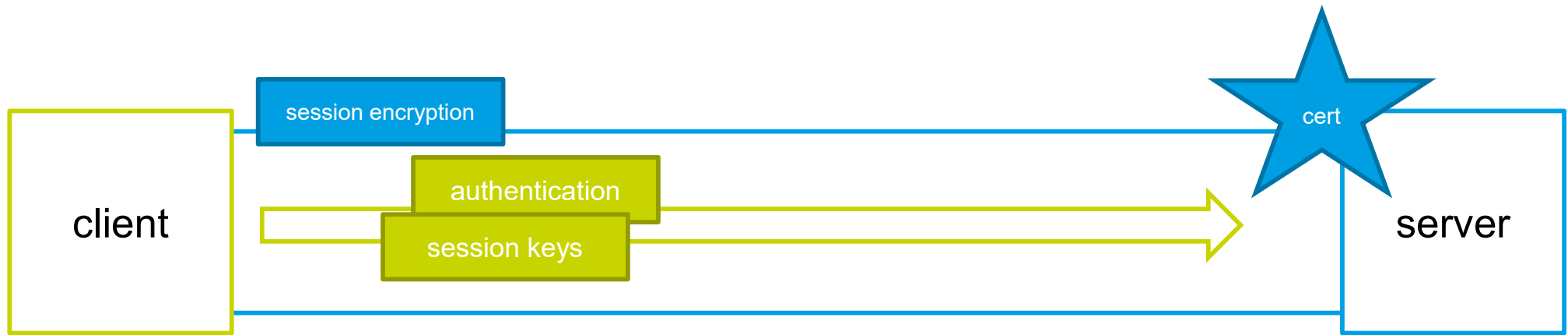
Name	Active Directory Domain Services Folder
Admin Accounts	gopas.virtual/Company/Service
Service Accounts	gopas.virtual/Company/Service

```
C:\>dir \\10.10.0.16\doc
The user name or password is incorrect.
```

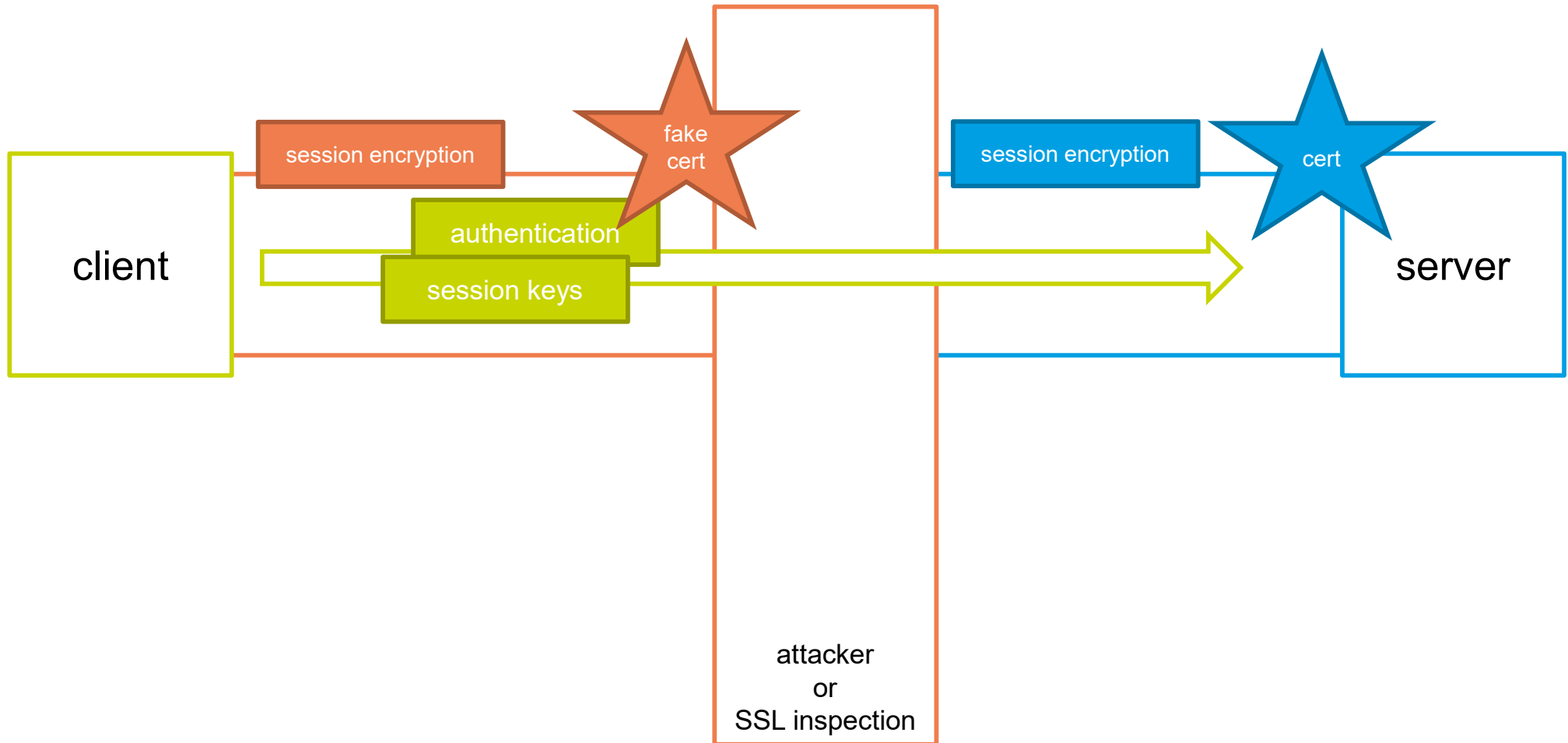
Protected Users (since 2012R2/8.1 machines) cons

- Kerberos ticket 4 hours
 - OK
- Kerberos TGT non-renewable
 - must type credentials every 4 hours
- Kerberos delegation disabled
 - business application
- good for **admin** accounts and **service** accounts
- **service** accounts **will not cache TGS** tickets on clients
 - slower responses with more processing round-trips due to no long-term key on the server side (KRB_AP_ERR_USER_TO_USER_REQUIRED)
 - possible problems on incorrectly developed GSSAPI software

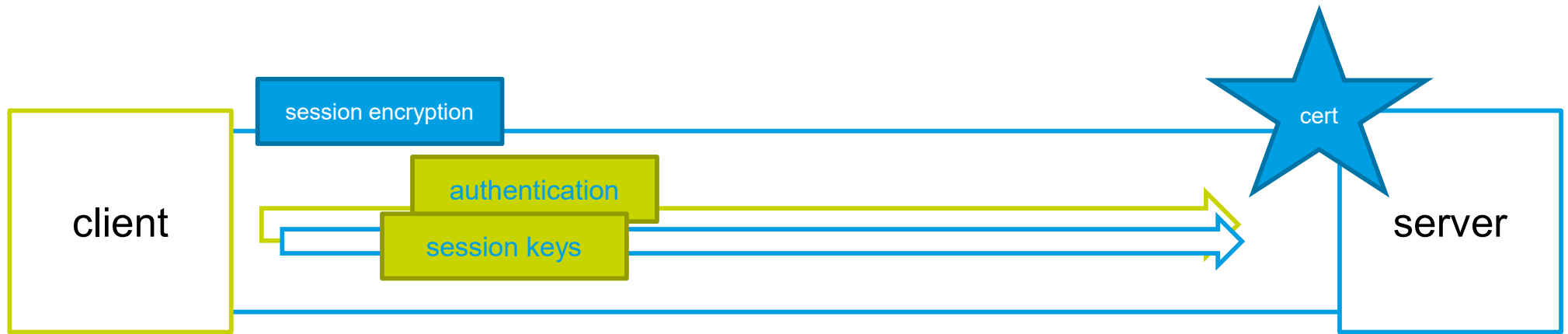
without Channel binding aka Extended protection for authentication aka Network Level Authentication (NTLM or Kerberos)



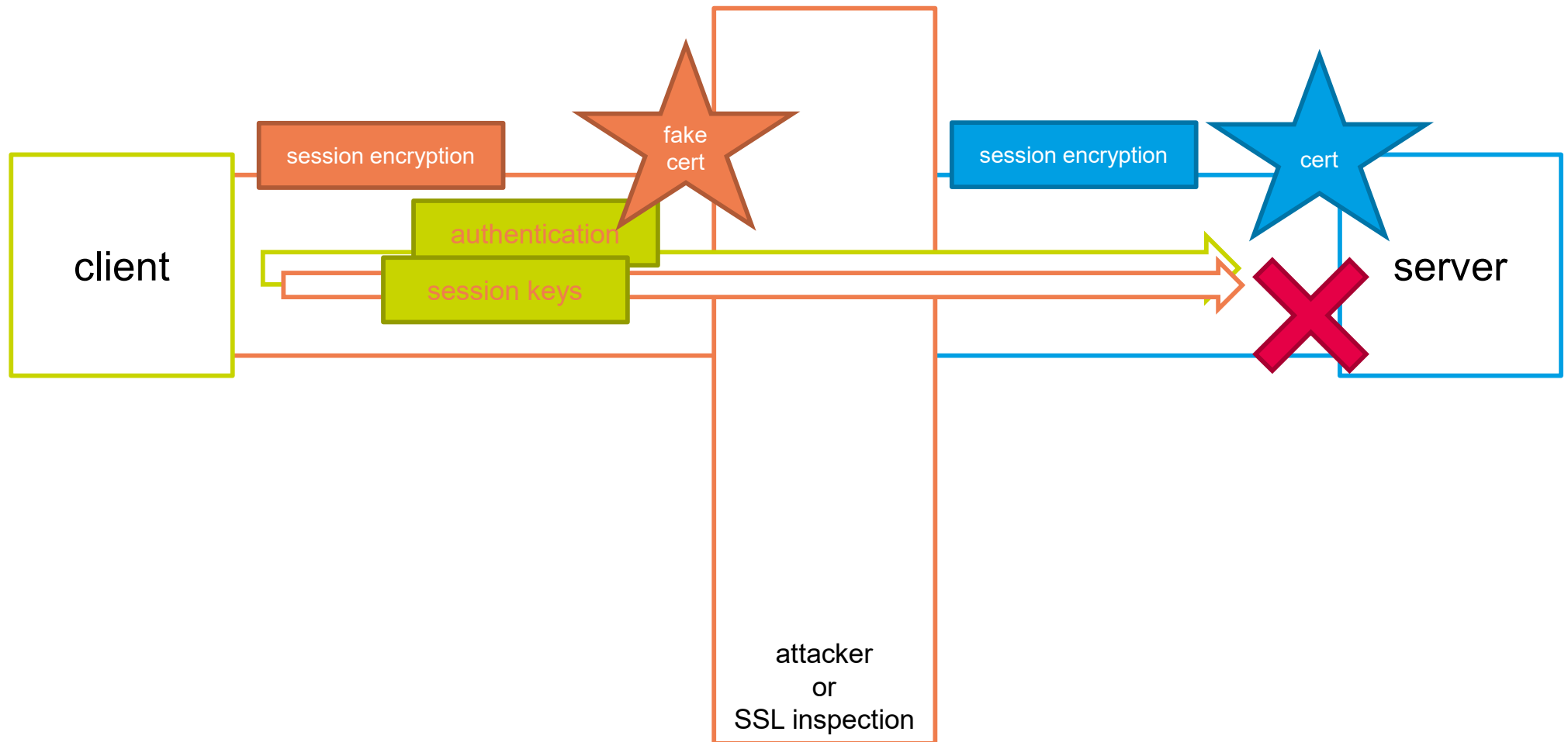
without Channel binding aka Extended protection for authentication aka Network Level Authentication (NTLM or Kerberos)



Channel binding aka Extended protection for authentication aka Network Level Authentication (NTLM or Kerberos)



no MITM with Channel binding aka Extended protection for authentication aka Network Level Authentication (NTLM or Kerberos)



CBT validation failure on the **resource server** event id 4625, status 0xC000035B = STATUS_BAD_BINDINGS

 Event Properties - Event 4625, Microsoft Windows security auditing.

General Details

Logon Type:	3
Account For Which Logon Failed:	
Security ID:	NULL SID
Account Name:	kamil
Account Domain:	GPS
Failure Information:	
Failure Reason:	An Error occurred during Logon.
Status:	0xC000035B
Sub Status:	0x0

Log Name:	Security		
Source:	Microsoft Windows security	Logged:	30.11.2021 14:34:56
Event ID:	4625	Task Category:	Logon
Level:	Information	Keywords:	Audit Failure

Browser support for CBT (Channel Binding aka Extended Protection for Authentication aka ExtendedProtectionTokenCheck)

- IE
 - supports in both NTLM and Negotiate providers
- Edge old
 - supports in both NTLM and Negotiate providers
- Edge Chromium
 - supports in both NTLM and Negotiate providers
- Chrome
 - supports in both NTLM and Negotiate providers
- Firefox
 - supports only with NTLM provider

Disabling CBT (channel binding token) on the client side (NTLM or Kerberos)

- enabled by default since Windows 7+ and Windows 2008 R2+
- disable for testing purposes only

`HKLM\System\CurrentControlSet\Control\LSA`

`SuppressExtendedProtection = DWORD = 3`

Enforce channel binding for LDAPS

Domain controller: LDAP server channel binding token requirements

Domain controller: LDAP server channel binding token re...



Security Policy Setting

Explain



Domain controller: LDAP server channel binding token requirements

☒ Define this policy setting

Always



Not everything non-Kerberos is NTLM - LDAP simple bind

Event Viewer

File Action View Help

Event Viewer (Local)

- Custom Views
- Windows Logs
 - Application
 - Security
 - Setup
 - System
 - Forwarded Events

Security Number of events: 208 318 (!) New events available

Keywords	Date and Time	Source	Event ID	Task Category
Audit Success	05.03.2026 17:03:26	Microsoft Windows security auditing.	4634	Logoff
Audit Success	05.03.2026 17:03:26	Microsoft Windows security auditing.	4624	Logon
Audit Success	05.03.2026 17:03:26	Microsoft Windows security auditing.	4648	Logon
Audit Success	05.03.2026 17:03:26	Microsoft Windows security auditing.	4776	Credential Validation
Audit Success	05.03.2026 17:03:26	Microsoft Windows security auditing.	4634	Logoff

The computer attempted to validate the c

Authentication Package: MICROSOFT_A

Logon Account: domain-admin

Source Workstation: GPS-DC1

Error Code: 0x0

Logon Information:

Logon Type: 3

New Logon:

Security ID: GPS\domain-admin

Account Name: domain-admin

Account Domain: GPS

Process Information:

Process ID: 0x3a4

Process Name: C:\Windows\System32\lsass.exe

Network Information:

Workstation Name: GPS-DC1

Source Network Address: 10.10.0.101

Source Port: 62279

Detailed Authentication Information:

Logon Process: Advapi

Authentication Package: MICROSOFT_AUTHENTICATION_PACKAGE_V1_0

Transited Services:

LDAP client IP address

Recommendations

- disable clear-text passwords stored on DC
- disable LM hashes stored on DC
 - 15+ char passwords
- may limit logon cache count
- enforce NTLMv2
 - enforce client NTLMv2, consider blocking LM/NTLM
- enforce NTLMv2 session security
 - + enforce SMB signing
- configured loopback aliases on NTLM servers
 - or assign an alternative DNS host name
- enable NTLM auditing
- use Protected Users group for sensitive accounts
- consider channel binding for any TLS traffic
 - HTTPS, LDAPS, RDPS with NLA, SQL